Diccionario CompTIA Security+ SY0-701

436 Términos - 5 Dominios

Distribución por Prioridad

ALTA: 220 términos (50.5%)
MEDIA: 162 términos (37.2%)
COMPLEMENTARIO: 54 términos (12.4%)

Índice de Contenidos

Dominio 1: Conceptos Generales de Seguridad (12% - 109 términos)

- 3DES (Triple DES)
- AAA Framework
- AIS (Automated Indicator Sharing)
- Modos de Cifrado de Bloque
- CA (Certificate Authority)
- CCMP (Counter Mode CBC-MAC Protocol)
- CMS (Content Management System)
- CRL (Certificate Revocation List)
- DES (Data Encryption Standard)
- DKIM (DomainKeys Identified Mail)
- DN (Distinguished Name)
- Data Masking (Enmascaramiento)
- Dictionary Attack
- Digital Signature
- ECC (Elliptic Curve Cryptography)
- ECDSA (Elliptic Curve Digital Signature Algorithm)
- EV Certificate (Extended Validation)
- GRE (Generic Routing Encapsulation)
- HMAC (Hash-based Message Authentication Code)
- Hardware Tokens
- Honeyfile
- Honeypot
- Just-in-Time Permissions (Permisos justo a tiempo)
- KEK (Key Encryption Key)
- Key Stretching
- MD5 (Message Digest 5)
- ML (Machine Learning)
- MSSP (Managed Security Service Provider)
- Non-Persistent VDI
- OID (Object Identifier)
- OpenID Connect
- PEM (Privacy Enhanced Mail)
- PKI (Public Key Infrastructure)
- PPP (Point-to-Point Protocol)
- Password History
- Politicas de Contraseña
- Quishing
- RC4 (Rivest Cipher 4)
- RIPEMD-160
- SAE (Simultaneous Authentication of Equals)
- SAN Certificate (Subject Alternative Name)
- SEH (Structured Exception Handling)
- SHA (Secure Hash Algorithm)
- SHTTP (Secure HTTP)
- SOW (Statement of Work)
- SRTP (Secure Real-time Transport Protocol)
- STARTTLS
- Secure Enclave
- Tipos de Controles de Seguridad
- Certificado Autofirmado
- Esteganografía
- 802.1X
- AES (Advanced Encryption Standard)
- Tipos de Biometria
- Blockchain
- CAPTCHA
- CIA Triad
- CRC (Cyclic Redundancy Check)
- Certificado Digital X.509
- DHE (Diffie-Hellman Ephemeral)
- DMARC (Domain-based Message Authentication)
- DSA (Digital Signature Algorithm)
- Defense in Depth
- Digital Certificate
- Disinformation
- ECDHE (Elliptic Curve Diffie-Hellman Ephemeral)
- EFS (Encrypting File System)
- FDE (Full Disk Encryption)
- Gap Analysis
- HSM (Hardware Security Module)
- Hashing
- Honeynet
- Honeytoken
- KDC (Key Distribution Center)
- Key Fob
- LEAP (Lightweight EAP)
- MDM (Mobile Device Management)
- MSP (Managed Service Provider)
- Minimum Password Age
- OCSP (Online Certificate Status Protocol)
- OTP (One-Time Password)
- PBKDF2 (Password-Based Key Derivation Function 2)
- PKCS (Public Key Cryptography Standards)
- PKI Trust Models
- Password Expiration
- Password Manager
- Pharming
- RA (Registration Authority)
- RFID Badge
- RSA
- SAML (Security Assertion Markup Language)
- SED (Self-Encrypting Drive)
- SFTP (SSH File Transfer Protocol)
- SHA-3
- SMTPS (SMTP Secure)
- SPF (Sender Policy Framework)
- SSID (Service Set Identifier)
- S/MIME (Secure/Multipurpose Internet Mail Extensions)
- Categorías de Controles
- Security Key
- Site Survey (Wireless)
- TKIP (Temporal Key Integrity Protocol)

- TPM (Trusted Platform Module)
- Vishing
- Watering Hole Attack
- Zero Trust
- Tokenización
- WPA2/WPA3
- Wildcard Certificate

Dominio 2: Amenazas, Vulnerabilidades y Mitigaciones (22% - 81 términos)

- APT (Advanced Persistent Threat)
- BEC (Business Email Compromise)
- Bluejacking
- Botnet
- Buffer Overflow
- CSRF (Cross-Site Request Forgery)
- CVSS (Common Vulnerability Scoring System)
- DLL Injection (Inyección DLL)
- Data Sanitization
- Dictionary Attack
- DoS (Denial of Service)
- Downgrade Attack
- False Negative
- Firmware
- Image-Based Threat Vectors
- Input Validation
- Jailbreaking (iOS)
- Legacy Hardware Vulnerabilities
- MITRE ATT&CK;
- Malware
- MitM (Man-in-the-Middle)
- PUP (Potentially Unwanted Program)
- Password Spraying
- Pretexting
- RAT (Remote Access Trojan)
- RFID Cloning
- Ransomware
- Replay Attack
- Rootkit
- SQL Injection (SQLi)
- Session Hijacking (Secuestro de sesión)
- Sideloading
- Spear Phishing
- Threat Actor (Actor de Amenaza)
- Troyano (Trojan)
- VM Escape
- War Driving
- Whaling
- Wireless Jamming
- XML Injection
- Zero-Day
- Attack Surface
- Birthday Attack
- Bluesnarfing
- Brute Force Attack
- C2 (Command and Control)
- CVE (Common Vulnerabilities and Exposures)
- DDoS (Distributed Denial of Service)
- DNS Spoofing (Envenenamiento DNS)
- Degaussing
- Directory Traversal
- Domain Hijacking
- Error Handling
- False Positive
- IV Attack
- Impersonation (Suplantación de identidad)
- IoC (Indicator of Compromise)
- LDAP Injection
- Logic Bomb
- Malicious Application Update
- Memory Injection
- Ataques NFC
- Pass the Hash
- Phishing
- Privilege Escalation (Escalada de privilegios)
- RCE (Remote Code Execution)
- Race Condition
- Reflected DDoS
- Rooting (Android)
- SCAP (Security Content Automation Protocol)
- SQL Injection (SQLi)
- Session Replay
- Smishing
- TOC/TOU (Time of Check/Time of Use)
- Threat Vector
- Typosquatting (URL Hijacking)
- Vishing
- Watering Hole Attack
- Wireless Disassociation
- Worm
- XSS (Cross-Site Scripting)

Dominio 3: Arquitectura de Seguridad (18% - 132 términos)

- ABAC (Attribute-Based Access Control)
- AH (Authentication Header)
- AUP (Acceptable Use Policy)
- Agent-Based Filtering
- Regla 3-2-1 de Backup
- Beacon Frame
- CAPTCHA
- CBC (Cipher Block Chaining)
- ACL (Access Control List)
- AIS (Automated Indicator Sharing)
- Adaptive Identity (Identidad Adaptativa)
- Air Gap (Entrehierro)
- Backup Generator (Generador de Respaldo)
- Blockchain
- CASB (Cloud Access Security Broker)
- CCMP (Counter Mode CBC-MAC Protocol)

- CMS (Content Management System)
- CTR (Counter Mode)
- IaaS (Infrastructure as a Service)
- SaaS (Software as a Service)
- Containerización
- DLP (Data Loss Prevention)
- DNS Filtering
- Data Retention Policy (Politica de Retencion de Datos)
- Dual Power Supply
- EAP-TTLS
- EDR (Endpoint Detection and Response)
- ESP (Encapsulating Security Payload)
- Firewall
- Full Tunnel VPN
- GRE (Generic Routing Encapsulation)
- Group Policy (GPO)
- HIPS (Host-based Intrusion Prevention System)
- Honeytoken
- Hybrid Cloud
- IEEE 802.1X
- IMAPS (IMAP over SSL/TLS)
- IPSec
- IPSec Tunnel Mode
- IPsec Transport Mode
- Journaling (Llevar un diario)
- Least Privilege
- MAC (Mandatory Access Control)
- MTTR (Mean Time to Repair)
- NAC (Network Access Control)
- NIDS (Network-based IDS)
- Network Tap
- PAC (Proxy Auto-Configuration)
- PEAP (Protected EAP)
- PSK (Pre-Shared Key)
- Proxy Server (Servidor Proxy)
- RAS (Remote Access Service)
- RTO (Recovery Time Objective)
- Remote Wipe (Borrado Remoto)
- RuBAC (Rule-Based Access Control)
- SDN (Software-Defined Networking)
- SELinux (Security-Enhanced Linux)
- SIEM (Security Information and Event Management)
- SNMP (Simple Network Management Protocol)
- SOW (Statement of Work)
- STARTTLS
- Sandboxing
- Secure Baseline (Linea de Base Segura)
- Site-to-Site VPN
- Split Tunnel VPN
- TKIP (Temporal Key Integrity Protocol)
- Time-of-Day Restrictions
- URL Scanning
- VDI (Virtual Desktop Infrastructure)
- VLSM (Variable Length Subnet Mask)
- VPN (Virtual Private Network)
- Virtualización
- WIDS (Wireless IDS)
- Warm Site (Sitio Calido)
- CSP (Cloud Service Provider)
- Clearance Levels
- PaaS (Platform as a Service)
- Cold Site (Sitio Frio)
- DAC (Discretionary Access Control)
- DMZ (Demilitarized Zone)
- Data Masking (Enmascaramiento de datos)
- Degaussing (Desmagnetizacion)
- EAP-TLS
- ECB (Electronic Codebook)
- EFS (Encrypting File System)
- FIM (File Integrity Monitoring)
- Implicit Deny (Firewall)
- GDPR (General Data Protection Regulation)
- Geofencing
- HIDS (Host-based IDS)
- Honeynet
- Hot Site
- IDS (Intrusion Detection System)
- IKE (Internet Key Exchange)
- IPS (Intrusion Prevention System)
- IPSec Transport Mode
- IPsec (IP Security)
- Implicit Deny (Denegación Implícita)
- Layer 7 Firewall (Application Layer Firewall)
- Load Balancing
- MTBF (Mean Time Between Failures)
- Machine Language (Lenguaje Maquina)
- NGFW (Next-Generation Firewall)
- NIPS (Network-based IPS)
- Non-Persistent VDI
- PDU (Power Distribution Unit)
- POP3S (POP3 over SSL/TLS)
- Port Mirroring (Duplicacion de puertos)
- RAID (Redundant Array of Independent Disks)
- RPO (Recovery Point Objective)
- Remote Access VPN (Client-to-Site)
- Replication (Replicacion)
- SASE (Secure Access Service Edge)
- SD-WAN (Software-Defined WAN)
- SHTTP (Secure HTTP)
- SMTPS (SMTP Secure)
- SOAR (Security Orchestration, Automation and Response)
- SSL VPN
- SWG (Secure Web Gateway)
- Screened Subnet (DMZ)
- Simulation (Ejercicio de simulación)
- Snapshot (Instantanea)
- Split Tunneling
- Tabletop Exercise
- UPS (Uninterruptible Power Supply)
- UTM (Unified Threat Management)
- VLAN (Virtual Local Area Network)
- VPC (Virtual Private Cloud)
- VTC (Video Teleconferencing)
- WAF (Web Application Firewall)
- WPA Enterprise
- XDR (Extended Detection and Response)

Dominio 4: Operaciones de Seguridad (28% - 60 términos)

- ABAC (Attribute-Based Access Control)
- AUP (Acceptable Use Policy)
- Automation (Security)
- Blue Team
- CBC (Cipher Block Chaining)
- CVE (Common Vulnerabilities and Exposures)
- Concurrent Session Usage
- DLP (Data Loss Prevention)
- Dark Web
- Data Processor (Procesador de Datos)
- E-Discovery (Electronic Discovery / Descubrimiento Electronico)
- Gray-Box Testing
- Impossible Travel
- Incident Response - Detection and Analysis
- Incident Response - Preparation
- JSON (JavaScript Object Notation)
- MDM (Mobile Device Management)
- Missing Logs
- OID (Object Identifier)
- Orchestration (Orquestacion)
- PCAP (Packet Capture)
- Passive Reconnaissance
- RFID (Radio Frequency Identification)
- Right to be Forgotten (Derecho a ser Olvidado)
- SDLC (Software Development Life Cycle)
- Security Key (Llave de Seguridad)
- Static Code Analysis (Analisis de Codigo Estatico)
- Technical Debt
- User Onboarding (Incorporacion de Usuario)
- White Team
- ARO (Annualized Rate of Occurrence)
- Active Reconnaissance
- Biometrics (Biometria)
- Bug Bounty
- CTR (Counter Mode)
- Code Signing
- DKIM (DomainKeys Identified Mail)
- DMARC (Domain-based Message Authentication, Reporting and Conformance)
- Data Controller (Controlador de Datos / Responsable del Tratamiento)
- Dynamic Code Analysis
- Fuzzing
- IRP (Incident Response Plan)
- Incident Response - Containment, Eradication, Recovery
- Incident Response - Post-Incident Activity
- IoC (Indicator of Compromise)
- MAC (Mandatory Access Control)
- Metadata (Metadatos)
- Normalization
- OpenID Connect
- Out-of-Cycle Logging
- Package Monitoring
- Purple Team
- Red Team
- SASE (Secure Access Service Edge)
- SNMP (Simple Network Management Protocol)
- Signatures (Security)
- TAXII (Trusted Automated Exchange of Intelligence Information)
- User Offboarding (Baja de Usuario)
- Vulnerability Scanning
- XML (eXtensible Markup Language)

Dominio 5: Gestión del Programa de Seguridad (20% - 54 términos)

- BCP (Business Continuity Plan)
- BYOD (Bring Your Own Device)
- COPE (Corporate Owned, Personally Enabled)
- CSP (Cloud Service Provider)
- CYOD (Choose Your Own Device)
- Cold Site
- DRP (Disaster Recovery Plan)
- Hot Site
- IRP (Incident Response Plan)
- Fases de Respuesta a Incidentes
- MBR (Master Boot Record)
- MSA (Master Service Agreement)
- MTTR (Mean Time To Repair)
- NTP (Network Time Protocol)
- OVAL (Open Vulnerability and Assessment Language)
- PDU (Power Distribution Unit)
- RAID 0
- RAID 5
- RTO (Recovery Time Objective)
- BPA (Business Partnership Agreement)
- Backup Generator
- CSO (Chief Security Officer)
- CTO (Chief Technology Officer)
- Chain of Custody
- DARPA (Defense Advanced Research Projects Agency)
- GPS (Global Positioning System)
- ICMP (Internet Control Message Protocol)
- ISO (International Organization for Standardization)
- Journaling
- MOU (Memorandum of Understanding)
- MTBF (Mean Time Between Failures)
- Mobile Site
- OTG (USB On-The-Go)
- PCI DSS (Payment Card Industry Data Security Standard)
- RAD (Rapid Application Development)
- RAID 10
- RPO (Recovery Point Objective)
- RTP (Real-time Transport Protocol)

- Replication
- Risk Exception
- Risk Register (Registro de Riesgos)
- Root Cause Analysis
- SLA (Service Level Agreement)
- Snapshot
- Technical Debt (Deuda Tecnica)
- Warm Site
- Risk Appetite
- Risk Mitigation
- Risk Transference
- SEH (Structured Exception Handling)
- SNMP (Simple Network Management Protocol)
- Tabletop Exercise
- UEM (Unified Endpoint Management)
- Work Order (WO)

Dominio 1: Conceptos Generales de Seguridad

Peso examen: 12% | Términos: 109

3DES (Triple DES)

Definición: Versión mejorada de DES aplicando cifrado 3 veces. Clave efectiva de 168 bits. Obsoleto desde 2023

Ejemplos:

- Usado en cajeros ATM legacy
- Sistemas de pago antiguos

Prioridad: COMPLEMENTARIO

802.1X

Definición: Estandar IEEE para control de acceso a red basado en puertos (NAC). Usa EAP para autenticacion. Requiere: Suplicante, Autenticador, Servidor AAA (RADIUS)

Ejemplos:

- WPA2/WPA3 Enterprise
- Autenticacion de switches con RADIUS
- Suplicante=cliente, Autenticador=AP/switch, AAA=RADIUS server

Prioridad: ALTA

AAA Framework

Definición: Authentication (verificar identidad), Authorization (dar permisos), Accounting (registrar acciones). Marco de control de acceso

Ejemplos:

- Login con usuario/contraseña (Authentication) → permisos de lectura/escritura (Authorization) → logs de acceso (Accounting)
- RADIUS y TACACS+ implementan AAA

Prioridad: ALTA

AES (Advanced Encryption Standard)

Definición: Algoritmo de cifrado simétrico estándar. Claves de 128, 192 o 256 bits. Rápido y seguro

Ejemplos:

- AES-256 para cifrado de disco BitLocker
- AES-128 en WPA2
- AES-GCM en TLS

Prioridad: ALTA

AIS (Automated Indicator Sharing)

Definición: Iniciativa de gobierno USA (DHS) para compartir indicadores de amenazas ciberneticas en tiempo real entre organizaciones

Ejemplos:

- Compartir IoCs entre gobierno y sector privado
- Formato STIX/TAXII
- Programa DHS CISA

Prioridad: MEDIA

Tipos de Biometria

Definición: Autenticacion basada en caracteristicas fisicas/comportamentales. Fisiologica: huella, iris, facial. Comportamental: firma, patron de tecleo, voz

Ejemplos:

- Fingerprint scanner (Touch ID)
- Iris/retina scan
- Facial recognition (Face ID)
- Voice recognition
- Gait analysis
- Metricas: FAR, FRR, CER

Prioridad: ALTA

Modos de Cifrado de Bloque

Definición: Formas de aplicar cifrado por bloques. ECB (simple/débil), CBC (encadenado), CFB (feedback), GCM (autenticado), CTR (contador)

Ejemplos:

- ECB: NO usar (patrones visibles)
- CBC: requiere IV
- GCM: cifrado + autenticación
- AES-256-GCM en TLS 1.3

Prioridad: MEDIA

Blockchain

Definición: Registro público distribuido (ledger) de transacciones enlazadas criptográficamente. Inmutable y descentralizado

Ejemplos:

- Bitcoin blockchain
- Ethereum
- Cada bloque contiene hash del anterior
- Inmutabilidad por consenso distribuido

Prioridad: COMPLEMENTARIO

CA (Certificate Authority)

Definición: Tercera parte confiable que emite, revoca y gestiona certificados digitales. Raiz de confianza en PKI

Ejemplos:

- DigiCert
- Let's Encrypt
- Verisign
- Root CA → Intermediate CA → End-entity certificates

Prioridad: ALTA

CAPTCHA

Definición: Challenge-Response para distinguir humanos de bots. Previene ataques automatizados (brute force, scraping, spam)

Ejemplos:

- Imagenes distorsionadas con texto
- Seleccionar semaforos en imagenes (reCAPTCHA v2)
- reCAPTCHA v3 analiza comportamiento sin interaccion

Prioridad: MEDIA

CCMP (Counter Mode CBC-MAC Protocol)

Definición: Protocolo de cifrado en WPA2. Basado en AES. Reemplaza TKIP. Mayor seguridad

Ejemplos:

- WPA2 usa CCMP
- Cifrado AES-128
- Integridad con CBC-MAC
- Estandar actual Wi-Fi

Prioridad: ALTA

CIA Triad

Definición: Tríada de seguridad fundamental: Confidencialidad (solo personas autorizadas acceden), Integridad (datos no modificados sin autorización), Disponibilidad (acceso cuando se necesita)

Ejemplos:

- Confidencialidad: cifrado de datos sensibles
- Integridad: hashing para verificar archivos
- Disponibilidad: sistemas redundantes y backups

Prioridad: ALTA

CMS (Content Management System)

Definición: Sistema de gestion de contenido web. Simplifica creacion y mantenimiento de sitios web sin codigo

Ejemplos:

- WordPress
- Drupal
- Joomla
- Vulnerabilidades: plugins desactualizados
- Requiere hardening

Prioridad: MEDIA

CRC (Cyclic Redundancy Check)

Definición: Función hash NO criptográfica para detección de errores. NO usar para seguridad, solo para verificar corrupción accidental

Ejemplos:

- CRC32 en archivos ZIP
- Detección de errores en transmisión de red

Prioridad: COMPLEMENTARIO

CRL (Certificate Revocation List)

Definición: Lista de certificados revocados publicada por CA. Actualizada periodicamente. Mas lento que OCSP

Ejemplos:

- Descarga de CRL completa
- Verificacion offline
- Actualizada cada 24-48 horas
- Tamaño puede ser grande

Prioridad: MEDIA

Certificado Digital X.509

Definición: Documento que vincula una clave pública a una identidad. Firmado por una CA. Contiene: titular, clave pública, CA emisora, periodo validez

Ejemplos:

- Certificado SSL/TLS para HTTPS
- Certificado de firma de código
- Certificado de usuario para S/MIME

Prioridad: ALTA

DES (Data Encryption Standard)

Definición: Algoritmo de cifrado simétrico OBSOLETO. Clave de 56 bits. Vulnerable a brute force. Reemplazado por AES

Ejemplos:

- Usado en sistemas legacy antiguos
- Sustituido por 3DES y luego AES

Prioridad: COMPLEMENTARIO

DHE (Diffie-Hellman Ephemeral)

Definición: Intercambio de claves Diffie-Hellman con claves efimeras temporales. Perfect Forward Secrecy. Nueva clave cada sesion

Ejemplos:

- TLS_DHE_RSA cipher suites
- PFS (Perfect Forward Secrecy)
- Protege sesiones pasadas
- ECDHE mas rapido

Prioridad: ALTA

DKIM (DomainKeys Identified Mail)

Definición: Firma digital en cabeceras de email para verificar autenticidad del remitente y que no fue modificado. Usa criptografia asimetrica

Ejemplos:

- Clave privada firma email saliente
- Clave publica en DNS TXT record
- Previene spoofing y phishing

Prioridad: ALTA

DMARC (Domain-based Message Authentication)

Definición: Politica de autenticacion de email que usa SPF y DKIM. Define que hacer con emails que fallan validacion (none/quarantine/reject)

Ejemplos:

- Publicar politica en DNS TXT: v=DMARC1; p=reject
- Recibir reportes de emails rechazados
- Proteccion contra phishing y spoofing

Prioridad: ALTA

DN (Distinguished Name)

Definición: Nombre único que identifica una entidad en certificado X.509. Contiene: CN (Common Name), O (Organization), OU, C (Country)

Ejemplos:

- CN=www.example.com, O=Example Inc, C=US
- Identifica titular del certificado

Prioridad: COMPLEMENTARIO

DSA (Digital Signature Algorithm)

Definición: Algoritmo para firmas digitales. Autenticacion, integridad, no repudio. Basado en logaritmo discreto. No para cifrado

Ejemplos:

- DSA keys 1024-3072 bits
- FIPS 186-4 standard
- Solo firmas, NO cifrado
- SSH host keys

Prioridad: ALTA

Data Masking (Enmascaramiento)

Definición: Ocultar datos sensibles reemplazándolos con caracteres genéricos. Preserva formato pero no contenido real

Ejemplos:

- Mostrar **** en campo de contraseña
- 4532-****-****-1234 para número de tarjeta
- Base de datos de prueba con datos enmascarados

Prioridad: MEDIA

Defense in Depth

Definición: Múltiples capas de seguridad. Si una falla, las demás protegen. Concepto de defensa en profundidad

Ejemplos:

- Firewall → IDS → WAF → Antivirus → EDR → SIEM
- Seguridad física + red + aplicación + datos

Prioridad: ALTA

Dictionary Attack

Definición: Ataque de fuerza bruta que usa lista de palabras comunes. Prueba contraseñas probables (diccionario). Mas eficiente que fuerza bruta pura

Ejemplos:

- rockyou.txt
- john.txt
- Lista de 10 millones de contraseñas
- Contraseñas comunes (password123, qwerty)

Prioridad: ALTA

Digital Certificate

Definición: Documento digital que verifica identidad de individuo/dispositivo/organizacion. Emitido por CA. Contiene clave publica + info del titular

Ejemplos:

- Certificado SSL/TLS para HTTPS
- Certificado de email S/MIME
- Componentes: Subject, Issuer, Public Key, Validity

Prioridad: ALTA

Digital Signature

Definición: Firma digital para verificar autenticidad e integridad de documentos. Usa criptografia asimetrica (firma con clave privada, verifica con publica)

Ejemplos:

- Firmar PDF con certificado
- Algoritmos: RSA, DSA, ECDSA
- Proporciona autenticacion, integridad, no repudio

Prioridad: ALTA

Disinformation

Definición: Informacion falsa o engañosa difundida deliberadamente para manipular o engañar. Diferente de misinformacion (no intencional)

Ejemplos:

- Campañas de desinformacion en redes sociales
- Deepfakes
- Propaganda maliciosa

Prioridad: MEDIA

ECC (Elliptic Curve Cryptography)

Definición: Criptografía de curva elíptica. Seguridad similar a RSA con claves más cortas. Eficiente para IoT y móviles

Ejemplos:

- ECDSA (firma digital)
- ECDHE (intercambio de claves)
- ECC 256-bit = RSA 3072-bit en seguridad

Prioridad: MEDIA

ECDHE (Elliptic Curve Diffie-Hellman Ephemeral)

Definición: Versión de Diffie-Hellman basada en curvas elípticas con claves efímeras. Más eficiente que DHE tradicional

Ejemplos:

- TLS 1.3 usa ECDHE
- Perfect Forward Secrecy con menor coste computacional

Prioridad: MEDIA

ECDSA (Elliptic Curve Digital Signature Algorithm)

Definición: DSA basado en criptografia de curva eliptica. Mas eficiente computacionalmente. Menor tamaño de clave para misma seguridad

Ejemplos:

- 256-bit ECDSA = 3072-bit RSA security
- Bitcoin signatures
- TLS certificates
- Mas rapido que RSA/DSA

Prioridad: ALTA

EFS (Encrypting File System)

Definición: Sistema de cifrado a nivel de archivo en Windows NTFS. Cifra archivos/carpetas individuales, NO todo el disco

Ejemplos:

- Cifrar carpeta 'Documentos' en Windows
- Protección por usuario
- Transparente tras autenticación

Prioridad: MEDIA

EV Certificate (Extended Validation)

Definición: Certificado con validacion extendida. Mayor nivel de verificacion de identidad. Mostraba barra verde en navegadores antiguos

Ejemplos:

- Validacion exhaustiva de organizacion
- Usado por bancos y ecommerce
- Mayor confianza del usuario

Prioridad: MEDIA

FDE (Full Disk Encryption)

Definición: Cifrado completo del disco por software. Protege TODOS los datos en reposo

Ejemplos:

- BitLocker (Windows)
- FileVault (macOS)
- LUKS (Linux)

Prioridad: ALTA

GRE (Generic Routing Encapsulation)

Definición: Protocolo de tunelizacion para encapsular protocolos de red dentro de IP. Usado en VPNs. NO cifrado por defecto

Ejemplos:

- GRE over IPsec para VPN
- Tunel punto a punto
- Protocolo 47
- Combinar con IPsec para seguridad

Prioridad: MEDIA

Gap Analysis

Definición: Proceso de identificar diferencias entre el estado actual de seguridad de una organización y el estado deseado/requerido

Ejemplos:

- Comparar seguridad actual con ISO 27001
- Identificar controles faltantes para compliance PCI DSS

Prioridad: MEDIA

HMAC (Hash-based Message Authentication Code)

Definición: Combina función hash con clave secreta para verificar autenticidad E integridad del mensaje

Ejemplos:

- HMAC-SHA256 en JWT
- Verificar que mensaje no fue alterado y proviene de quien dice

Prioridad: MEDIA

HSM (Hardware Security Module)

Definición: Dispositivo hardware dedicado para gestión segura de claves criptográficas. Nivel empresarial. FIPS 140-2/3 certified

Ejemplos:

- Almacenar claves raíz de CA
- Firma de transacciones bancarias
- Thales, AWS CloudHSM

Prioridad: MEDIA

Hardware Tokens

Definición: Dispositivos fisicos para autenticacion. Tipos: Key fob (OTP), Security key (FIDO2/U2F), RFID badge, Smart card

Ejemplos:

- RSA SecurID (key fob con OTP)
- YubiKey (FIDO2)
- Tarjeta RFID para acceso fisico
- Smart card con PKI

Prioridad: ALTA

Hashing

Definición: Función criptográfica unidireccional que genera un valor de longitud fija (hash) a partir de datos de cualquier tamaño. NO es reversible

Ejemplos:

- SHA-256 para verificar integridad de archivos
- Bcrypt/Argon2 para almacenar contraseñas
- MD5 (obsoleto, vulnerable a colisiones)

Prioridad: ALTA

Honeyfile

Definición: Archivo falso colocado estratégicamente para detectar accesos no autorizados. Genera alerta cuando se accede

Ejemplos:

- passwords.xlsx falso en compartido de red
- Documento con información tentadora pero falsa
- Trigger de alerta al abrir

Prioridad: COMPLEMENTARIO

Honeynet

Definición: Red completa de honeypots interconectados que simula infraestructura real. Entorno controlado para observar ataques complejos

Ejemplos:

- Red falsa con servidores web, DB, y workstations
- Simular red corporativa completa para estudio de APTs

Prioridad: COMPLEMENTARIO

Honeypot

Definición: Sistema trampa que simula ser vulnerable para atraer atacantes y estudiar sus técnicas. Contiene vulnerabilidades aparentes monitorizadas

Ejemplos:

- Servidor SSH falso con credenciales débiles
- Base de datos con datos ficticios
- Detectar técnicas de ataques

Prioridad: MEDIA

Honeytoken

Definición: Dato falso (credencial, API key, URL) que cuando se usa genera alerta de compromiso. NO debe usarse en producción real

Ejemplos:

- Credenciales falsas en código fuente
- API key dummy que alerta si se usa
- Email/usuario inexistente que si se usa indica compromiso

Prioridad: COMPLEMENTARIO

Just-in-Time Permissions (Permisos justo a tiempo)

Definición: Acceso efimero temporal. Privilegios otorgados solo cuando se necesitan. Se revocan automaticamente tras uso. Reduce superficie de ataque

Ejemplos:

- Admin access por 2 horas
- Elevacion temporal privilegios
- Zero Standing Privileges
- PAM JIT

Prioridad: ALTA

KDC (Key Distribution Center)

Definición: Servidor centralizado que distribuye claves criptográficas y autentica usuarios. Componente principal de Kerberos

Ejemplos:

- Kerberos KDC emite TGT (Ticket Granting Ticket)
- Active Directory usa KDC

Prioridad: MEDIA

KEK (Key Encryption Key)

Definición: Clave usada para cifrar otras claves criptográficas. Añade capa adicional de seguridad en gestión de claves

Ejemplos:

- Master key que protege claves de sesión
- Key wrapping en HSM

Prioridad: COMPLEMENTARIO

Key Fob

Definición: Token fisico que genera OTP (One-Time Password) basado en tiempo (TOTP) o contador (HOTP). Factor de autenticacion

Ejemplos:

- RSA SecurID
- Codigo de 6-8 digitos cambia cada 30-60 segundos
- Sincronizado con servidor AAA

Prioridad: MEDIA

Key Stretching

Definición: Tecnica que incrementa tiempo de calculo para derivar clave. Dificulta ataques de fuerza bruta. Aplica funcion hash multiples veces

Ejemplos:

- PBKDF2
- bcrypt
- scrypt
- Argon2
- 10000+ iteraciones
- Combate password cracking

Prioridad: MEDIA

LEAP (Lightweight EAP)

Definición: Protocolo de autenticacion inalambrica DEPRECADO de Cisco. Vulnerable a ataques de diccionario. Reemplazado por PEAP y EAP-TLS

Ejemplos:

- NO usar en produccion - obsoleto
- Usar WPA2/WPA3 Enterprise con PEAP o EAP-TLS en su lugar

Prioridad: MEDIA

MD5 (Message Digest 5)

Definición: Función hash OBSOLETA de 128 bits. Vulnerable a colisiones. NO usar para seguridad

Ejemplos:

- Checksum de archivos (solo integridad no crítica)
- Reemplazado por SHA-256

Prioridad: COMPLEMENTARIO

MDM (Mobile Device Management)

Definición: Gestion centralizada de dispositivos moviles: configuracion, seguridad, aplicaciones, politicas. Control remoto de smartphones/tablets corporativos

Ejemplos:

- Borrado remoto de dispositivo perdido
- Forzar cifrado y PIN
- Distribuir apps corporativas
- Geofencing
- Soluciones: Intune, Jamf, MobileIron

Prioridad: ALTA

ML (Machine Learning)

Definición: Aprendizaje automatico. IA que aprende de datos sin programacion explicita. Deteccion anomalias, threat hunting

Ejemplos:

- Deteccion malware con ML
- Behavioral analysis
- Anomaly detection
- Neural networks
- Supervised/Unsupervised learning

Prioridad: ALTA

MSP (Managed Service Provider)

Definición: Proveedor externo de servicios IT completos. Gestion de infraestructura, soporte, mantenimiento para empresas sin personal IT

Ejemplos:

- Gestion de red y servidores
- Help desk
- Backup y DR
- Monitoreo 24/7

Prioridad: MEDIA

MSSP (Managed Security Service Provider)

Definición: Proveedor externo especializado en seguridad IT. Ofrece SOC, SIEM, gestion de vulnerabilidades, respuesta a incidentes

Ejemplos:

- SOC as a Service
- Gestion de firewall y IDS
- Threat intelligence
- Compliance monitoring

Prioridad: ALTA

Minimum Password Age

Definición: Tiempo minimo que debe usarse contraseña antes de cambiarla. Previene cambios rapidos para burlar historial. Minimo 1 dia tipico

Ejemplos:

- 1 dia minimo
- Evita cambiar 12 veces seguidas para reutilizar antigua
- Complementa Password History

Prioridad: COMPLEMENTARIO

Non-Persistent VDI

Definición: Escritorio virtual que revierte a estado original al cerrar sesion. Compartido entre usuarios. Cambios no se guardan

Ejemplos:

- Kioscos publicos
- Call centers
- Usuario cierra sesion → desktop se resetea
- Ahorro de almacenamiento

Prioridad: MEDIA

OCSP (Online Certificate Status Protocol)

Definición: Protocolo para verificar estado de revocacion de certificado en tiempo real. Mas rapido que CRL

Ejemplos:

- Consulta individual de certificado
- Respuesta: good/revoked/unknown
- Puerto 80 HTTP
- OCSP stapling mejora rendimiento

Prioridad: ALTA

OID (Object Identifier)

Definición: Identificador único numérico jerárquico usado en PKI para identificar objetos, algoritmos, políticas y extensiones

Ejemplos:

- OID 1.2.840.113549.1.1.11 = SHA256withRSA
- Identificar política de certificado

Prioridad: COMPLEMENTARIO

OTP (One-Time Password)

Definición: Contraseña valida para una sola sesion o transaccion. Genera codigo temporal. Componente MFA. Caduca rapidamente

Ejemplos:

- TOTP (Time-based)
- HOTP (Counter-based)
- SMS OTP
- Google Authenticator
- Valido 30-60 segundos

Prioridad: ALTA

OpenID Connect

Definición: Capa de identidad sobre OAuth 2.0. Permite autenticacion federada (Single Sign-On). Devuelve ID token (JWT) con info del usuario

Ejemplos:

- Login con Google/Microsoft en apps terceras
- ID token + Access token
- Proveedores: Google, Okta, Auth0

Prioridad: ALTA

PBKDF2 (Password-Based Key Derivation Function 2)

Definición: Algoritmo de key stretching que aplica función hash múltiples veces (iteraciones) para derivar clave desde password. Protege contra brute force

Ejemplos:

- 100,000 iteraciones SHA-256
- Almacenamiento seguro de contraseñas
- Alternativas: bcrypt, scrypt, Argon2

Prioridad: MEDIA

PEM (Privacy Enhanced Mail)

Definición: Formato codificacion Base64 para certificados y claves. Texto ASCII entre headers BEGIN/END. Estandar de facto

Ejemplos:

- -----BEGIN CERTIFICATE-----
- -----END PRIVATE KEY-----
- Base64 encoded
- Formato texto legible

Prioridad: MEDIA

PKCS (Public Key Cryptography Standards)

Definición: Conjunto de estándares para criptografía de clave pública. Define formatos para claves, certificados, firmas, etc.

Ejemplos:

- PKCS#12 (.pfx/.p12) para exportar certificado + clave privada
- PKCS#7 para firmas digitales
- PKCS#10 para CSR

Prioridad: COMPLEMENTARIO

PKI (Public Key Infrastructure)

Definición: Infraestructura de gestión de certificados digitales. Incluye CA (Certificate Authority), RA (Registration Authority), certificados X.509

Ejemplos:

- CA emite certificado SSL para sitio web
- RA verifica identidad del solicitante
- CRL lista certificados revocados

Prioridad: ALTA

PKI Trust Models

Definición: Modelos de confianza en infraestructura de clave publica: Single CA, Hierarchical, Mesh, Web of Trust, Bridge, Hybrid

Ejemplos:

- Hierarchical: root CA + intermediate CAs
- Mesh: cross-certification entre CAs
- Bridge: conectar PKIs separadas

Prioridad: MEDIA

PPP (Point-to-Point Protocol)

Definición: Protocolo para enlace punto a punto dedicado entre dos dispositivos de red. Autenticacion, cifrado, compresion

Ejemplos:

- Conexiones dial-up
- Enlace entre routers
- Autenticacion PAP/CHAP
- Base de PPTP y PPPoE

Prioridad: MEDIA

Password Expiration

Definición: Politica que fuerza cambio de contraseña periodicamente. Caduca tras X dias. Mitiga riesgo de credenciales comprometidas

Ejemplos:

- Cambio cada 90 dias
- Expiracion 60 dias
- NIST ya NO recomienda expiracion automatica
- Cambio solo si compromiso

Prioridad: MEDIA

Password History

Definición: Politica que recuerda N contraseñas previas. Impide reutilizacion de contraseñas antiguas. Mejora seguridad en cambios periodicos

Ejemplos:

- Recordar ultimas 12 contraseñas
- Windows: Store 24 passwords
- No reutilizar ultimas 5 contraseñas

Prioridad: MEDIA

Password Manager

Definición: Aplicacion que almacena y gestiona contraseñas de forma segura. Cifrado de boveda. Genera contraseñas fuertes. Una contraseña maestra

Ejemplos:

- LastPass
- KeePass
- 1Password
- Bitwarden
- Cifrado AES-256
- Autorrelleno de formularios

Prioridad: ALTA

Politicas de Contraseña

Definición: Reglas de complejidad, longitud, historial, expiracion. Requisitos: minimo caracteres, mayusculas, numeros, simbolos

Ejemplos:

- Minimo 12 caracteres
- Cambio cada 90 dias (NIST ya no recomienda expiracion)
- No reusar ultimas 5 contraseñas
- Lockout tras 5 intentos fallidos

Prioridad: ALTA

Pharming

Definición: Redireccion de trafico web a sitio falso mediante envenenamiento DNS o modificacion de archivo hosts. Sin interaccion del usuario

Ejemplos:

- Modificar archivo hosts local
- DNS cache poisoning
- Usuario escribe URL correcta pero va a sitio falso

Prioridad: ALTA

Quishing

Definición: Phishing mediante codigos QR maliciosos. Victima escanea QR que lleva a sitio phishing o descarga malware

Ejemplos:

- QR falso en email
- QR en parking meter scam
- Redireccion a sitio phishing

Prioridad: MEDIA

RA (Registration Authority)

Definición: Entidad de PKI que verifica la identidad del solicitante antes de que CA emita el certificado. Intermediario entre usuario y CA

Ejemplos:

- Verificar documentos de identidad antes de emitir certificado
- Aprobar CSR antes de enviar a CA

Prioridad: COMPLEMENTARIO

RC4 (Rivest Cipher 4)

Definición: Cifrado de flujo obsoleto. Usado en WEP y SSL antiguo. Vulnerabilidades conocidas. Deprecated

Ejemplos:

- WEP encryption (inseguro)
- SSL/TLS antiguo (prohibido)
- Stream cipher
- Vulnerabilidades Fluhrer-McGrew

Prioridad: MEDIA

RFID Badge

Definición: Tarjeta con chip RFID para control de acceso fisico. Comunicacion por radiofrecuencia sin contacto

Ejemplos:

- Tarjeta de empleado para puertas
- Frecuencias: 125kHz (LF), 13.56MHz (HF)
- Vulnerable a clonacion y skimming

Prioridad: MEDIA

RIPEMD-160

Definición: Funcion hash criptografica de 160 bits. Alternativa a SHA-1. Usado en Bitcoin

Ejemplos:

- RIPEMD-160 en Bitcoin addresses
- Hash de 160 bits (20 bytes)
- Menos usado que SHA

Prioridad: COMPLEMENTARIO

RSA

Definición: Algoritmo de cifrado asimétrico. Par de claves pública/privada. Usado para cifrado y firmas digitales

Ejemplos:

- Certificados SSL/TLS
- Firma digital de emails S/MIME
- Intercambio seguro de claves simétricas
- Claves de 2048-4096 bits

Prioridad: ALTA

SAE (Simultaneous Authentication of Equals)

Definición: Metodo de autenticacion en WPA3 que reemplaza el handshake PSK de WPA2. Resistente a ataques offline de fuerza bruta

Ejemplos:

- WPA3-Personal usa SAE
- Proteccion contra ataques de diccionario incluso capturando handshake

Prioridad: ALTA

SAML (Security Assertion Markup Language)

Definición: Estandar XML para intercambio de autenticacion/autorizacion entre Identity Provider (IdP) y Service Provider (SP). SSO empresarial

Ejemplos:

- Login corporativo unico para multiples apps SaaS
- IdP (AD FS, Okta) emite SAML assertion
- SP (Salesforce, AWS) consume assertion

Prioridad: ALTA

SAN Certificate (Subject Alternative Name)

Definición: Certificado que puede asegurar múltiples dominios/subdominios. Extensión del campo SAN en X.509

Ejemplos:

- Certificado para www.ejemplo.com, mail.ejemplo.com, ftp.ejemplo.com
- Más flexible que wildcard

Prioridad: MEDIA

SED (Self-Encrypting Drive)

Definición: Disco duro/SSD con cifrado por hardware integrado. Transparente para el usuario. Más rápido que software

Ejemplos:

- SSD Samsung con cifrado AES-256
- Protección si roban laptop
- Cumplimiento FIPS

Prioridad: MEDIA

SEH (Structured Exception Handling)

Definición: Mecanismo de Windows para manejar excepciones. Vulnerable a ataques de buffer overflow que sobrescriben punteros SEH

Ejemplos:

- Ataque SEH overwrite
- SafeSEH y SEHOP como mitigaciones
- DEP y ASLR complementan proteccion

Prioridad: COMPLEMENTARIO

SFTP (SSH File Transfer Protocol)

Definición: Protocolo de transferencia de archivos sobre SSH. Cifrado completo. NO es FTP sobre SSL

Ejemplos:

- Puerto 22 (SSH)
- Alternativa segura a FTP
- FileZilla con SFTP

Prioridad: MEDIA

SHA (Secure Hash Algorithm)

Definición: Familia de funciones hash criptográficas. SHA-1 (obsoleto), SHA-2 (SHA-256, SHA-512 - recomendado), SHA-3 (último estándar)

Ejemplos:

- SHA-256 para blockchain Bitcoin
- SHA-512 para passwords
- SHA-1 DEPRECADO (colisiones)

Prioridad: ALTA

SHA-3

Definición: Familia de funciones hash criptograficas mas reciente. Mayor seguridad que SHA-2. Algoritmo Keccak

Ejemplos:

- SHA3-256
- SHA3-512
- Resistente a ataques de colision
- Reemplazo de SHA-2 para maxima seguridad

Prioridad: ALTA

SHTTP (Secure HTTP)

Definición: Protocolo OBSOLETO para transferencia segura web. Reemplazado por HTTPS (HTTP over TLS). No confundir con HTTPS

Ejemplos:

- NO usar - obsoleto desde 1990s
- Diferente de HTTPS
- Reemplazado por SSL/TLS

Prioridad: COMPLEMENTARIO

SMTPS (SMTP Secure)

Definición: SMTP con SSL/TLS DEPRECADO. Puerto 465/TCP. Reemplazado por STARTTLS. Cifrado desde inicio de conexion

Ejemplos:

- Puerto 465 (deprecado)
- Usar STARTTLS puerto 587 en su lugar
- Implicit TLS

Prioridad: COMPLEMENTARIO

SOW (Statement of Work)

Definición: Documento detallado que describe trabajo a realizar en proyecto. Define entregables, cronograma, costos, requisitos

Ejemplos:

- SOW para implementacion de red
- Alcance del proyecto
- Entregables especificos
- Diferente de SLA/MSA

Prioridad: MEDIA

SPF (Sender Policy Framework)

Definición: Record DNS que especifica que servidores pueden enviar email desde un dominio. Previene email spoofing

Ejemplos:

- v=spf1 ip4:192.0.2.0/24 include:_spf.google.com -all
- Softfail (~all) vs Hardfail (-all)
- Complementa DKIM y DMARC

Prioridad: ALTA

SRTP (Secure Real-time Transport Protocol)

Definición: Protocolo para cifrar audio/video en tiempo real. Usado en VoIP y videoconferencia

Ejemplos:

- Llamadas VoIP cifradas
- WebRTC usa SRTP
- Zoom/Teams para confidencialidad de llamadas

Prioridad: COMPLEMENTARIO

SSID (Service Set Identifier)

Definición: Nombre de red inalambrica. Puede ocultarse (SSID oculto) pero no es medida de seguridad efectiva

Ejemplos:

- Cambiar SSID por defecto del router
- Ocultar SSID no previene ataques de descubrimiento

Prioridad: MEDIA

STARTTLS

Definición: Comando para actualizar conexion no cifrada a cifrada con TLS. Usado en SMTP, IMAP, POP3. Puerto 587 para SMTP

Ejemplos:

- SMTP puerto 587 con STARTTLS
- Comienza sin cifrar, luego upgrade a TLS
- Mejor practica actual vs SMTPS

Prioridad: ALTA

S/MIME (Secure/Multipurpose Internet Mail Extensions)

Definición: Estándar para cifrar y firmar digitalmente emails. Requiere certificados X.509

Ejemplos:

- Email cifrado en Outlook
- Firma digital de correo
- Certificado personal para S/MIME

Prioridad: MEDIA

Secure Enclave

Definición: Entorno protegido y aislado dentro de CPU para procesar datos sensibles. Hardware dedicado para operaciones criptográficas

Ejemplos:

- Apple Secure Enclave para Touch ID
- Intel SGX
- ARM TrustZone

Prioridad: COMPLEMENTARIO

Categorías de Controles

Definición: Técnico/Lógico (tecnología/sistemas), Gerencial/Administrativo (políticas/procedimientos), Operacional (personas/procesos diarios), Físico (instalaciones materiales)

Ejemplos:

- Técnico: cifrado, firewall, EDR
- Gerencial: políticas de seguridad, formación
- Operacional: guardias, procedimientos de backup
- Físico: cerraduras, cámaras, vallas

Prioridad: ALTA

Tipos de Controles de Seguridad

Definición: Preventivo (evita incidentes), Detective (detecta incidentes), Correctivo (corrige tras incidente), Compensatorio (alternativa cuando el control preferido no es viable), Directivo (políticas y procedimientos), Disuasorio (desalienta ataques)

Ejemplos:

- Preventivo: firewall/AV
- Detective: IDS/SIEM/CCTV
- Correctivo: backups
- Compensatorio: MFA si no hay biometría
- Directivo: AUP
- Disuasorio: cámaras visibles

Prioridad: ALTA

Security Key

Definición: Token de hardware para autenticacion sin contraseña. Soporta FIDO2/U2F/WebAuthn. Resistente a phishing

Ejemplos:

- YubiKey
- Google Titan Key
- Autenticacion tocando boton fisico
- Funciona via USB/NFC/Bluetooth

Prioridad: ALTA

Certificado Autofirmado

Definición: Certificado NO emitido por CA. La entidad se firma a sí misma. NO confiable por defecto en navegadores. Uso en entornos internos/dev

Ejemplos:

- Servidor de prueba local
- Red interna corporativa
- Navegador muestra advertencia de seguridad

Prioridad: MEDIA

Site Survey (Wireless)

Definición: Analisis de ubicacion para diseño de red inalambrica. Identifica: cobertura, interferencias, potencia de señal optima, ubicacion de APs

Ejemplos:

- Heat map de cobertura Wi-Fi
- Detectar interferencias de 2.4GHz (microondas, Bluetooth)
- Optimizar ubicacion de APs para roaming

Prioridad: MEDIA

Esteganografía

Definición: Ocultar datos dentro de otro archivo (imagen, audio, video). NO es cifrado, es ocultación

Ejemplos:

- Mensaje oculto en píxeles de imagen
- Datos en metadatos de MP3
- Menos común que cifrado

Prioridad: COMPLEMENTARIO

TKIP (Temporal Key Integrity Protocol)

Definición: Protocolo de cifrado para mejorar WEP. Usado en WPA1. DEPRECADO - reemplazado por CCMP en WPA2

Ejemplos:

- WPA con TKIP (obsoleto)
- Claves temporales por paquete
- Usar WPA2/WPA3 con CCMP/AES

Prioridad: MEDIA

TPM (Trusted Platform Module)

Definición: Chip criptográfico en placa base para almacenar claves, certificados y realizar operaciones de seguridad. Secure boot, cifrado de disco

Ejemplos:

- BitLocker usa TPM para cifrado
- Almacenar claves RSA de forma segura
- Attestation de integridad del sistema

Prioridad: ALTA

Tokenización

Definición: Reemplazar dato sensible con token/referencia no sensible. Dato real se almacena en bóveda segura separada

Ejemplos:

- Token de pago en lugar de número de tarjeta real
- PCI DSS compliance
- Dato original NO se puede recuperar del token sin acceso a bóveda

Prioridad: MEDIA

Vishing

Definición: Phishing por voz (telefono/VoIP). Atacante llama haciendose pasar por entidad legitima para robar informacion

Ejemplos:

- Llamada falsa de soporte tecnico
- IRS scam calls
- Spoofing de caller ID

Prioridad: ALTA

WPA2/WPA3

Definición: Protocolos de seguridad Wi-Fi. WPA2 usa AES-CCMP. WPA3 añade SAE (mejor proteccion contra fuerza bruta) y cifrado individualizado

Ejemplos:

- WPA2-Personal (PSK)
- WPA3-Enterprise con 802.1X y RADIUS
- WPA3-SAE protege contra KRACK

Prioridad: ALTA

Watering Hole Attack

Definición: Compromiso de sitio web frecuentado por objetivo. Infectar sitio legitimo para atacar a sus visitantes

Ejemplos:

- Infectar sitio de industria especifica
- Comprometer blog tecnico para atacar desarrolladores
- Plataforma: Websites

Prioridad: MEDIA

Wildcard Certificate

Definición: Certificado que asegura un dominio principal y TODOS sus subdominios de primer nivel usando asterisco (*)

Ejemplos:

- *.ejemplo.com cubre: www.ejemplo.com, mail.ejemplo.com, ftp.ejemplo.com
- NO cubre sub.sub.ejemplo.com

Prioridad: MEDIA

Zero Trust

Definición: Modelo de seguridad que NO confía en ninguna entidad automáticamente. Verificar siempre, dentro o fuera de la red. 'Never trust, always verify'

Ejemplos:

- Verificar cada conexión incluso dentro de la LAN corporativa
- MFA obligatorio para todos los accesos
- Microsegmentación de red
- Adaptive identity basada en contexto

Prioridad: ALTA

Dominio 2: Amenazas, Vulnerabilidades y Mitigaciones

Peso examen: 22% | Términos: 81

APT (Advanced Persistent Threat)

Definición: Ataque cibernetico sofisticado y prolongado. Bien financiado (nation-states). Objetivo especifico. Persistente en red

Ejemplos:

- APT29 (Cozy Bear - Rusia)
- APT28 (Fancy Bear)
- Tacticas de evasion avanzadas
- Meses/años en red sin detectar

Prioridad: ALTA

Attack Surface

Definición: Suma de todos los puntos de vulnerabilidad donde atacante puede interactuar/comprometer sistema. Mayor superficie = mayor riesgo

Ejemplos:

- Puertos abiertos
- Aplicaciones web
- APIs
- Usuarios
- Reduccion: deshabilitar servicios innecesarios

Prioridad: ALTA

BEC (Business Email Compromise)

Definición: Ataque sofisticado de phishing dirigido a empresas. Suplanta identidad de ejecutivo o proveedor para transferencias fraudulentas

Ejemplos:

- Email falso del CEO pidiendo transferencia urgente
- Factura falsa de proveedor legítimo
- Millones de dólares perdidos

Prioridad: ALTA

Birthday Attack

Definición: Ataque criptográfico basado en paradoja del cumpleaños. Busca colisiones en funciones hash

Ejemplos:

- Encontrar 2 inputs diferentes con mismo hash MD5
- Explotar colisiones en firmas digitales

Prioridad: COMPLEMENTARIO

Bluejacking

Definición: Envío de mensajes no solicitados a dispositivos Bluetooth cercanos. Molesto pero NO roba datos

Ejemplos:

- Enviar mensaje 'Hola' a todos los dispositivos BT cercanos
- Marketing invasivo via Bluetooth

Prioridad: COMPLEMENTARIO

Bluesnarfing

Definición: Acceso no autorizado a dispositivo Bluetooth. Robo de datos (contactos, mensajes, fotos). Explota vulnerabilidades Bluetooth

Ejemplos:

- Robo contactos telefono
- Acceso calendario
- Descarga mensajes SMS
- Vulnerabilidad Bluetooth legacy

Prioridad: MEDIA

Botnet

Definición: Red de equipos infectados (zombies) controlados remotamente. Usada para DDoS, spam, cryptomining. Comando y control (C2)

Ejemplos:

- Mirai botnet
- Zeus botnet
- IoT botnets
- Miles/millones de dispositivos
- C2 server
- IRC/HTTP C2

Prioridad: ALTA

Brute Force Attack

Definición: Ataque que prueba TODAS las combinaciones posibles de contraseñas hasta encontrar la correcta. Alto uso de recursos

Ejemplos:

- Probar todas las contraseñas de 8 caracteres
- Crackear hash con diccionario + variaciones
- Mitigación: lockout, MFA, contraseñas largas

Prioridad: ALTA

Buffer Overflow

Definición: Vulnerabilidad por escribir más datos de los que cabe en buffer de memoria. Permite sobrescribir memoria adyacente y ejecutar código arbitrario

Ejemplos:

- Stack overflow
- Heap overflow
- Explotación de servicio con input sin validar

Prioridad: MEDIA

C2 (Command and Control)

Definición: Servidor que controla malware/bots remotamente. Envía comandos y recibe datos robados

Ejemplos:

- Bot se conecta a C2 para recibir instrucciones
- Exfiltración de datos a servidor C2

Prioridad: ALTA

CSRF (Cross-Site Request Forgery)

Definición: Ataque que engaña a usuario para ejecutar acciones no deseadas en sitio donde esta autenticado. Explota confianza del sitio en navegador

Ejemplos:

- Cambiar contraseña sin conocimiento
- Transferencia bancaria forzada
- Mitigacion: CSRF tokens
- SameSite cookies

Prioridad: ALTA

CVE (Common Vulnerabilities and Exposures)

Definición: Sistema de identificacion unica de vulnerabilidades. Formato: CVE-YEAR-NUMBER. Mantenido por MITRE

Ejemplos:

- CVE-2021-44228 (Log4Shell)
- CVE-2014-0160 (Heartbleed)
- Usado en patch management y scanners

Prioridad: ALTA

CVSS (Common Vulnerability Scoring System)

Definición: Sistema de puntuación de gravedad de vulnerabilidades. Escala 0.0-10.0. Crítico (9.0-10.0), Alto (7.0-8.9), Medio (4.0-6.9), Bajo (0.1-3.9)

Ejemplos:

- Log4Shell: CVSS 10.0 (Crítico)
- Factores: vector de ataque, complejidad, privilegios requeridos

Prioridad: ALTA

DDoS (Distributed Denial of Service)

Definición: Ataque desde múltiples fuentes (botnet) para saturar un servicio y hacerlo inaccesible. Versión distribuida del DoS

Ejemplos:

- Ataque SYN flood desde botnet
- Amplificación DNS/NTP
- Botnet Mirai atacando Dyn (2016)

Prioridad: ALTA

DLL Injection (Inyección DLL)

Definición: Técnica para inyectar código malicioso (DLL) en proceso legítimo de Windows. Evasión de detección

Ejemplos:

- Malware inyecta DLL en explorer.exe
- Rootkit usando DLL injection

Prioridad: MEDIA

DNS Spoofing (Envenenamiento DNS)

Definición: Proporcionar información DNS falsa al resolver para redirigir tráfico a servidor malicioso

Ejemplos:

- Modificar cache DNS para redirigir google.com a IP maliciosa
- Ataque Man-in-the-Middle via DNS

Prioridad: ALTA

Data Sanitization

Definición: Eliminar/sobrescribir datos de forma permanente. Metodos: Overwriting, Degaussing, Destruccion fisica, Crypto-shredding

Ejemplos:

- DoD 5220.22-M (7 pases)
- Degaussing de discos magneticos
- Triturar discos SSD
- Eliminar claves de cifrado (crypto-shredding)

Prioridad: ALTA

Degaussing

Definición: Eliminar datos de medios magneticos (HDD, cintas) usando campo magnetico intenso. Destruye datos y hace medio inutilizable

Ejemplos:

- Degausser para HDDs antes de desechar
- NO funciona en SSDs (usar destruccion fisica)
- Certificacion de sanitizacion

Prioridad: MEDIA

Dictionary Attack

Definición: Ataque que prueba contraseñas desde lista predefinida (diccionario) de passwords comunes. Más rápido que brute force

Ejemplos:

- Lista: password, 123456, admin, qwerty
- Rockyou.txt (14M passwords)
- Más eficiente que probar todo el keyspace

Prioridad: ALTA

Directory Traversal

Definición: Ataque que accede a archivos fuera de directorio web. Usa secuencias "../" para subir directorios. Lectura de archivos sensibles del sistema

Ejemplos:

- ../../etc/passwd
- ../../../windows/system32/config/sam
- Input validation
- Whitelist de archivos permitidos

Prioridad: ALTA

DoS (Denial of Service)

Definición: Ataque que satura un servicio para hacerlo inaccesible. Desde una sola fuente

Ejemplos:

- Ping flood
- SYN flood desde una IP
- Objetivo: hacer caer el servicio

Prioridad: ALTA

Domain Hijacking

Definición: Apropiacion ilegitima de dominio. Cambio no autorizado de registrante o DNS. Phishing, robo de credenciales del registrar

Ejemplos:

- Robo credenciales GoDaddy
- Transferencia no autorizada a otro registrar
- Cambio de DNS a servidor atacante

Prioridad: MEDIA

Downgrade Attack

Definición: Forzar uso de protocolo/cifrado más débil y obsoleto para facilitar compromiso

Ejemplos:

- Forzar TLS 1.0 en lugar de TLS 1.3
- SSL stripping a HTTP
- POODLE attack contra SSL 3.0

Prioridad: MEDIA

Error Handling

Definición: Manejo seguro de errores sin revelar informacion sensible. Mensajes genericos al usuario, detalles solo en logs internos

Ejemplos:

- NO mostrar stack traces a usuarios
- Mensajes genericos: Error procesando solicitud
- Loggear detalles completos en servidor

Prioridad: ALTA

False Negative

Definición: Sistema de seguridad NO detecta amenaza real. Falso sentido de seguridad. MAS PELIGROSO que falso positivo

Ejemplos:

- Antivirus no detecta malware nuevo
- IDS no alerta sobre intrusion real
- Firewall permite trafico malicioso

Prioridad: ALTA

False Positive

Definición: Sistema de seguridad alerta sobre actividad normal como amenaza. Genera fatiga de alertas y reduce eficiencia

Ejemplos:

- Antivirus bloquea software legitimo
- IDS alerta sobre escaneo de seguridad autorizado
- DLP bloquea transferencia legitima

Prioridad: ALTA

Firmware

Definición: Software embebido en chip hardware. Controla funciones de bajo nivel del dispositivo. Difícil de actualizar

Ejemplos:

- BIOS/UEFI
- Firmware de router
- Firmware de SSD
- Rootkits pueden infectar firmware

Prioridad: MEDIA

IV Attack

Definición: Ataque contra cifrado WEP. Explota debilidad de Initialization Vector (IV) de 24 bits. Colecta IVs para crackear clave WEP

Ejemplos:

- airodump-ng captura IVs
- aircrack-ng crackea WEP
- 40000-85000 IVs necesarios
- WEP obsoleto

Prioridad: MEDIA

Image-Based Threat Vectors

Definición: Amenazas mediante imagenes: Steganography (ocultar datos), Deepfakes (manipulacion), Malware-embedded images

Ejemplos:

- Steganografia en PNG
- Deepfake de CEO para BEC
- Exploit en JPEG
- Brand impersonation con logos

Prioridad: MEDIA

Impersonation (Suplantación de identidad)

Definición: Hacerse pasar por otra persona u organización legítima para ganar confianza y acceso

Ejemplos:

- Vestirse como técnico de IT
- Email que parece del CEO
- Página web que imita banco

Prioridad: ALTA

Input Validation

Definición: Validar toda entrada de usuario antes de procesarla. Previene injection, XSS, buffer overflow. Whitelist mejor que blacklist

Ejemplos:

- Rechazar caracteres especiales en formularios
- Validar tipo de dato (numeros, emails)
- Parametrized queries contra SQL injection

Prioridad: ALTA

IoC (Indicator of Compromise)

Definición: Evidencia forense que indica posible intrusión o actividad maliciosa. Hashes, IPs, dominios, patrones de comportamiento

Ejemplos:

- Hash MD5 de malware conocido
- IP de servidor C2
- Múltiples logins fallidos
- Tráfico a dominio sospechoso

Prioridad: ALTA

Jailbreaking (iOS)

Definición: Obtener acceso root en dispositivo iOS eliminando restricciones de Apple. Instalar apps no autorizadas

Ejemplos:

- Cydia
- Acceso a filesystem
- Instalar apps fuera de App Store

Prioridad: MEDIA

LDAP Injection

Definición: Inyeccion de codigo en consultas LDAP. Manipula filtros de busqueda LDAP. Bypass de autenticacion o extraccion de datos. Similar a SQLi

Ejemplos:

- usuario=*)(uid=*))(|(uid=*
- Bypass login LDAP
- Extraccion de objetos AD
- Input validation + parametrizacion

Prioridad: MEDIA

Legacy Hardware Vulnerabilities

Definición: Vulnerabilidad principal: falta de actualizaciones de seguridad y parches. Hardware obsoleto sin soporte

Ejemplos:

- Windows XP sin parches
- Hardware sin actualizacion firmware
- End-of-Life equipment
- Mitigacion: segmentacion de red

Prioridad: ALTA

Logic Bomb

Definición: Codigo malicioso que permanece inactivo hasta que se cumple condicion especifica. Entonces ejecuta payload. Dificil de detectar

Ejemplos:

- Activacion en fecha especifica
- Trigger: despido empleado
- Borrar datos si no login 30 dias
- Sabotaje interno

Prioridad: MEDIA

MITRE ATT&CK;

Definición: Framework de tacticas y tecnicas de adversarios. Base de conocimiento de comportamiento de atacantes. Matriz de TTPs

Ejemplos:

- 14 tacticas: Reconnaissance, Initial Access, Execution...
- Tecnicas numeradas: T1059.001 (PowerShell)
- Usado para threat hunting y CTI

Prioridad: ALTA

Malicious Application Update

Definición: Malware instalado via actualizacion falsa de software. Vector: codigo sin firmar, canal HTTP, servidor comprometido, supply chain attack

Ejemplos:

- NotPetya via actualizacion MeDoc
- SolarWinds supply chain attack
- Fake Flash update
- Mitigacion: code signing, HTTPS

Prioridad: ALTA

Malware

Definición: Software malicioso diseñado para dañar, explotar o comprometer sistemas. Tipos: virus, gusano, troyano, ransomware, spyware, rootkit

Ejemplos:

- WannaCry (ransomware)
- Emotet (troyano)
- Stuxnet (gusano)

Prioridad: ALTA

Memory Injection

Definición: Introducir codigo externo en espacio de memoria de proceso en ejecucion. Tecnica de evasion de AV

Ejemplos:

- DLL injection
- Process hollowing
- Reflective DLL injection
- Usado por malware avanzado

Prioridad: ALTA

MitM (Man-in-the-Middle)

Definición: Atacante se interpone entre dos partes que se comunican para interceptar/modificar tráfico. También llamado On-Path attack

Ejemplos:

- ARP spoofing en LAN
- SSL stripping
- Rogue WiFi AP
- Interceptar credenciales en texto claro

Prioridad: ALTA

Ataques NFC

Definición: Vulnerabilidades en Near Field Communication: eavesdropping (escucha), data interception, relay attacks, DoS

Ejemplos:

- Relay attack para duplicar tarjeta de pago
- Eavesdropping en transacción NFC
- Corto alcance dificulta ataques remotos

Prioridad: COMPLEMENTARIO

PUP (Potentially Unwanted Program)

Definición: Software no necesariamente malicioso pero no deseado. Instalado sin conocimiento claro del usuario. Adware, toolbars

Ejemplos:

- Toolbar de navegador instalada con otro software
- Adware que muestra anuncios
- Bloatware preinstalado

Prioridad: COMPLEMENTARIO

Pass the Hash

Definición: Técnica de autenticación usando hash de contraseña capturado sin necesidad de descifrar. Común en Windows NTLM

Ejemplos:

- Usar hash NTLM para autenticarse sin conocer password en texto claro
- Movimiento lateral en AD

Prioridad: MEDIA

Password Spraying

Definición: Probar POCAS contraseñas comunes contra MUCHAS cuentas. Evita lockout de cuenta individual

Ejemplos:

- Password123 contra 1000 usuarios
- Evita bloqueo por intentos fallidos en una cuenta
- Más sigiloso que brute force

Prioridad: ALTA

Phishing

Definición: Ataque de ingeniería social mediante email fraudulento que simula ser legítimo para robar credenciales o instalar malware

Ejemplos:

- Email falso de 'banco' pidiendo verificar cuenta
- Link a página clonada de login
- Adjunto malicioso simulando ser factura

Prioridad: ALTA

Pretexting

Definición: Técnica de ingeniería social donde atacante crea escenario falso (pretexto) para engañar y obtener información

Ejemplos:

- Llamar haciéndose pasar por IT support pidiendo password
- Crear historia falsa de emergencia para obtener acceso

Prioridad: MEDIA

Privilege Escalation (Escalada de privilegios)

Definición: Obtener permisos superiores a los asignados inicialmente. Vertical (usuario → admin) u horizontal (usuario → otro usuario)

Ejemplos:

- Exploit de kernel para root
- Sudo misconfiguration
- Movimiento lateral entre cuentas

Prioridad: ALTA

RAT (Remote Access Trojan)

Definición: Troyano que permite control remoto completo del sistema comprometido. Acceso backdoor persistente

Ejemplos:

- njRAT
- DarkComet
- Control total: webcam, keylogger, robo de archivos

Prioridad: ALTA

RCE (Remote Code Execution)

Definición: Vulnerabilidad que permite ejecutar código arbitrario en sistema remoto. Muy crítica (CVSS 9-10)

Ejemplos:

- Log4Shell permite RCE
- Exploit que ejecuta comandos del atacante
- Compromiso total del servidor

Prioridad: ALTA

RFID Cloning

Definición: Copiar datos de tarjeta/tag RFID a otro dispositivo RFID. Clonación de credenciales de acceso

Ejemplos:

- Clonar tarjeta de acceso al edificio
- Duplicar tag RFID de parking
- Legítimo para backups, malicioso para acceso no autorizado

Prioridad: COMPLEMENTARIO

Race Condition

Definición: Vulnerabilidad donde resultado depende de secuencia/timing de eventos. Acceso concurrente a recurso compartido causa comportamiento inesperado

Ejemplos:

- TOC/TOU (Time-of-Check/Time-of-Use)
- Dos threads modifican variable simultaneamente
- Sincronizacion incorrecta

Prioridad: MEDIA

Ransomware

Definición: Malware que cifra archivos de victima. Exige pago (rescate) para clave de descifrado. Doble extorsion: cifrado + amenaza de publicacion

Ejemplos:

- WannaCry
- Ryuk
- REvil
- Locky
- Bitcoin payment
- Cifrado AES + RSA
- Atacar backups

Prioridad: ALTA

Reflected DDoS

Definición: Ataque DDoS que usa servidores intermedios para amplificar trafico. Falsifica IP origen (spoofing). Servidores reflejan respuestas a victima

Ejemplos:

- DNS amplification
- NTP amplification
- Factor 50x-100x amplificacion
- Abuso de servidores publicos

Prioridad: ALTA

Replay Attack

Definición: Capturar y reenviar tráfico de autenticación válido para ganar acceso. Mitigación: timestamps, nonces

Ejemplos:

- Capturar token de autenticación y reenviarlo
- Repetir transacción bancaria capturada

Prioridad: MEDIA

Rooting (Android)

Definición: Obtener acceso root/administrativo completo en dispositivo Android. Anula garantía y rompe seguridad

Ejemplos:

- SuperSU
- Magisk
- Acceso total al sistema operativo
- Bypass de restricciones del fabricante

Prioridad: MEDIA

Rootkit

Definición: Malware que se oculta en el sistema operativo a nivel kernel o boot. Muy difícil de detectar y eliminar

Ejemplos:

- Rootkit en firmware UEFI
- Bootkit que infecta MBR
- Sony BMG rootkit (2005)

Prioridad: MEDIA

SCAP (Security Content Automation Protocol)

Definición: Suite de especificaciones para automatizar gestion de vulnerabilidades, medicion de configuracion, compliance. Incluye CVE, CVSS, CCE, CPE

Ejemplos:

- SCAP scanners (Nessus, OpenSCAP)
- Validacion automatica de configuraciones contra baseline
- Integracion con SIEM

Prioridad: MEDIA

SQL Injection (SQLi)

Definición: Vulnerabilidad que permite inyectar código SQL malicioso en queries. Compromete base de datos

Ejemplos:

- ' OR 1=1-- para bypass de autenticación
- UNION SELECT para extraer datos
- xp_cmdshell para ejecución de comandos en SQL Server

Prioridad: ALTA

SQL Injection (SQLi)

Definición: Inyeccion de codigo SQL malicioso en campos de entrada para ejecutar comandos no autorizados en base de datos

Ejemplos:

- OR 1=1-- para bypass de login
- UNION SELECT para exfiltrar datos
- Mitigacion: parametrized queries
- Input validation

Prioridad: ALTA

Session Hijacking (Secuestro de sesión)

Definición: Robo de Session ID válido para suplantar usuario autenticado. NO requiere credenciales

Ejemplos:

- Robar cookie de sesión via XSS
- Sniffing de Session ID en red no cifrada
- Acceder a cuenta sin password

Prioridad: ALTA

Session Replay

Definición: Ataque que captura y reenvía sesion valida. Intercepta trafico autenticado. Replay de tokens o cookies de sesion. Bypass de autenticacion

Ejemplos:

- Captura token JWT
- Replay cookie de sesion
- Kerberos ticket replay
- Mitigacion: nonce, timestamp, SSL/TLS

Prioridad: ALTA

Sideloading

Definición: Instalar apps móviles desde fuentes NO oficiales (fuera de App Store/Play Store). Riesgo de malware

Ejemplos:

- Instalar APK desde sitio web
- Apps no verificadas
- Bypass de protecciones de tienda oficial

Prioridad: MEDIA

Smishing

Definición: Phishing mediante SMS. Mensaje de texto con link malicioso o pidiendo información sensible

Ejemplos:

- SMS: 'Su paquete no pudo entregarse, haga clic aquí'
- Mensaje de 'banco' pidiendo verificar tarjeta

Prioridad: MEDIA

Spear Phishing

Definición: Phishing dirigido a persona o organización específica. Altamente personalizado con información de OSINT

Ejemplos:

- Email al CFO simulando ser del CEO pidiendo transferencia
- Investigación previa en LinkedIn del objetivo

Prioridad: ALTA

TOC/TOU (Time of Check/Time of Use)

Definición: Vulnerabilidad de condicion de carrera. Estado de recurso cambia entre verificacion y uso. Race condition attack

Ejemplos:

- Verificar permisos archivo, luego cambiar archivo antes de usar
- Symbolic link attack
- File system race

Prioridad: MEDIA

Threat Actor (Actor de Amenaza)

Definición: Entidad que representa una amenaza. Tipos: Nation-state (estado), APT (amenaza persistente avanzada), Hacktivist (activismo), Insider (interno), Script kiddie (aficionado)

Ejemplos:

- APT28 (Fancy Bear) - grupo ruso
- Insider malicioso filtrando datos
- Script kiddie usando exploits públicos

Prioridad: ALTA

Threat Vector

Definición: Metodo/ruta que atacante usa para introducir amenaza. Email, malware, drive-by download, ingenieria social

Ejemplos:

- Email phishing
- USB malicioso
- Descarga drive-by
- Mensajeria instantanea
- Archivos PDF/Office maliciosos

Prioridad: ALTA

Troyano (Trojan)

Definición: Malware disfrazado de software legítimo. NO se auto-replica. Puerta trasera para el atacante

Ejemplos:

- Emotet
- TrickBot
- Aplicación crackeada con malware oculto

Prioridad: ALTA

Typosquatting (URL Hijacking)

Definición: Registro de dominios con errores tipograficos de sitios populares. Explota errores de escritura usuarios. Phishing y distribucion malware

Ejemplos:

- gogle.com en vez de google.com
- amazom.com
- fcebook.com
- Captura trafico mal escrito

Prioridad: ALTA

VM Escape

Definición: Vulnerabilidad de virtualizacion donde activos de una VM acceden/comprometen otra VM. Rompe aislamiento entre VMs

Ejemplos:

- Exploit en hypervisor
- Compartir recursos entre VMs inseguro
- Resource reuse vulnerability
- Mitigacion: parchar hypervisor

Prioridad: ALTA

Vishing

Definición: Phishing por voz (llamada telefónica). Atacante se hace pasar por entidad legítima

Ejemplos:

- Llamada de 'soporte Microsoft' diciendo que PC está infectado
- Falso banco pidiendo verificar transacción

Prioridad: MEDIA

War Driving

Definición: Busqueda de redes WiFi vulnerables conduciendo vehiculo. Mapeo de redes inalambricas. Identifica redes abiertas o debiles

Ejemplos:

- Kismet
- NetStumbler
- WiGLE.net (mapa mundial)
- GPS + WiFi adapter
- Buscar WEP o WPA debil

Prioridad: COMPLEMENTARIO

Watering Hole Attack

Definición: Comprometen sitio web legítimo que visita el objetivo para infectar a visitantes. Ataque indirecto

Ejemplos:

- Infectar sitio de noticias de industria específica
- Visitantes descargan malware al navegar

Prioridad: MEDIA

Whaling

Definición: Spear phishing dirigido específicamente a ejecutivos de alto nivel (C-level)

Ejemplos:

- Fraude al CEO
- BEC (Business Email Compromise) a director financiero

Prioridad: MEDIA

Wireless Disassociation

Definición: Ataque que envia frames de desasociacion falsos. Desconecta clientes de AP. Tipo de DoS inalambrico. Frames de gestion no autenticados

Ejemplos:

- aireplay-ng --deauth
- Preparacion para WPA handshake capture
- Evil Twin attack
- Frame management spoofing

Prioridad: ALTA

Wireless Jamming

Definición: Ataque DoS que interfiere señal inalámbrica usando ruido en misma frecuencia. Hace inaccesible WiFi/Bluetooth/GPS

Ejemplos:

- Jamming de señal WiFi 2.4GHz
- Bloquear GPS
- Ataque de denegación de servicio físico

Prioridad: MEDIA

Worm

Definición: Malware autorreplicante. Se propaga automaticamente por red sin intervencion humana. Consume recursos de red

Ejemplos:

- Morris Worm
- Code Red
- SQL Slammer
- Conficker
- Propagacion por vulnerabilidades
- Saturacion de red

Prioridad: ALTA

XML Injection

Definición: Inyeccion de codigo XML malicioso. Manipula parseo de XML. XXE (External Entity) para leer archivos. Ataque a aplicaciones que procesan XML

Ejemplos:

-
- Leer archivos internos
- SSRF via XXE
- Deshabilitar external entities

Prioridad: ALTA

XSS (Cross-Site Scripting)

Definición: Inyeccion de script malicioso en sitio web confiable. Browser del usuario ejecuta script del atacante. Roba cookies/sesiones

Ejemplos:

- Reflected XSS: script en URL
- Stored XSS: script guardado en DB
- DOM-based XSS
- Mitigacion: sanitizar input, CSP

Prioridad: ALTA

Zero-Day

Definición: Vulnerabilidad desconocida por el fabricante. No existe parche. Ventana de 0 días para defenderse

Ejemplos:

- Log4Shell antes de ser descubierta públicamente
- Exploit usado por APT antes de patch

Prioridad: ALTA

Dominio 3: Arquitectura de Seguridad

Peso examen: 18% | Términos: 132

ABAC (Attribute-Based Access Control)

Definición: Control de acceso basado en atributos de: usuario, recurso, entorno. Politicas dinamicas y granulares

Ejemplos:

- Permitir acceso si: departamento=HR AND ubicacion=oficina AND hora_laboral=true
- AWS IAM policies
- XACML standard

Prioridad: MEDIA

ACL (Access Control List)

Definición: Lista de reglas de control de acceso. Filtra trafico por IP, puerto, protocolo. Implementada en routers, switches, firewalls

Ejemplos:

- Permit tcp 192.168.1.0/24 any eq 80
- Deny ip any any
- Router ACL
- Firewall rules
- Order matters

Prioridad: ALTA

AH (Authentication Header)

Definición: Componente de IPSec que proporciona SOLO autenticación e integridad, NO cifrado. Menos usado que ESP

Ejemplos:

- Protocolo 51
- Verifica que paquete no fue modificado pero NO lo cifra

Prioridad: COMPLEMENTARIO

AIS (Automated Indicator Sharing)

Definición: Iniciativa DHS para compartir indicadores de amenazas en tiempo real. Gobierno + sector privado. STIX/TAXII

Ejemplos:

- US-CERT AIS
- STIX format
- TAXII transport
- Threat intel sharing
- Indicadores IoC automaticos

Prioridad: MEDIA

AUP (Acceptable Use Policy)

Definición: Politica de uso aceptable. Reglas de comportamiento para usuarios de sistemas IT. Que esta permitido/prohibido

Ejemplos:

- No uso personal excesivo
- Prohibido pirateria
- No acceso no autorizado
- Consecuencias violaciones
- Firma requerida

Prioridad: ALTA

Adaptive Identity (Identidad Adaptativa)

Definición: Control de acceso Zero Trust dinamico. Considera contexto: identidad, dispositivo, ubicacion, comportamiento. Decisiones de acceso en tiempo real

Ejemplos:

- MFA si login inusual
- Bloqueo desde pais no autorizado
- Require device compliance
- Azure Conditional Access

Prioridad: ALTA

Agent-Based Filtering

Definición: Filtrado web mediante agente instalado en endpoint. Funciona incluso fuera de red corporativa. Control de contenido en laptop remota

Ejemplos:

- Software de filtrado web en laptop corporativa
- Politicas aplicadas localmente
- Alternativa a proxy centralizado

Prioridad: MEDIA

Air Gap (Entrehierro)

Definición: Aislamiento fisico completo de red. Sistema sin conexion a redes externas. Maxima seguridad por separacion fisica

Ejemplos:

- Sistema SCADA aislado
- Red clasificada militar
- Sistema critico sin Internet
- Transferencia via USB solo

Prioridad: ALTA

Regla 3-2-1 de Backup

Definición: 3 copias de datos, en 2 tipos de medios diferentes, 1 copia offsite (fuera del sitio)

Ejemplos:

- Original + backup en NAS + backup en nube
- Protección contra ransomware y desastres físicos

Prioridad: ALTA

Backup Generator (Generador de Respaldo)

Definición: Generador electrico que arranca cuando falla alimentacion principal. Diesel/gas. Autonomia horas/dias. Complementa UPS

Ejemplos:

- Generador diesel datacenter
- Arranque automatico 30 seg
- Tanque 24-48h autonomia
- Testing mensual requerido

Prioridad: MEDIA

Beacon Frame

Definición: Frame de gestion WiFi. AP anuncia presencia y caracteristicas. Contiene SSID, capacidades, tasas. Broadcast periodico

Ejemplos:

- SSID broadcast
- Intervalo 100ms tipico
- Contiene: SSID, canales, cifrado soportado
- Detectable por scanners WiFi

Prioridad: COMPLEMENTARIO

Blockchain

Definición: Libro mayor distribuido publico. Registro inmutable de transacciones. Descentralizado. Criptografia + consenso. Base de criptomonedas

Ejemplos:

- Bitcoin blockchain
- Ethereum
- Smart contracts
- Registro inmutable
- Proof of Work/Stake

Prioridad: COMPLEMENTARIO

CAPTCHA

Definición: Test para distinguir humanos de bots. Desafio-respuesta visual/audio. Previene automatizacion. reCAPTCHA de Google popular

Ejemplos:

- Seleccionar semaforos en imagenes
- Escribir texto distorsionado
- reCAPTCHA v3 (invisible)
- Anti-bot protection

Prioridad: MEDIA

CASB (Cloud Access Security Broker)

Definición: Intermediario de seguridad entre usuarios y aplicaciones cloud. Visibilidad, DLP, compliance, threat protection en SaaS

Ejemplos:

- Controlar uso de Dropbox/OneDrive
- DLP en Office 365
- Detectar shadow IT

Prioridad: MEDIA

CBC (Cipher Block Chaining)

Definición: Modo cifrado de bloques. Cada bloque XOR con anterior. IV para primer bloque. Popular pero vulnerable a padding oracle

Ejemplos:

- AES-CBC
- IV necesario
- Padding oracle vulnerability
- Encadenamiento de bloques
- Usado en TLS antiguo

Prioridad: ALTA

CCMP (Counter Mode CBC-MAC Protocol)

Definición: Protocolo cifrado WPA2/WPA3. Basado en AES. Reemplazo de TKIP. Modo contador + autenticacion CBC-MAC

Ejemplos:

- WPA2 encryption
- AES-128 o AES-256
- Mas seguro que TKIP
- WPA3 usa CCMP

Prioridad: ALTA

CMS (Content Management System)

Definición: Sistema gestion de contenido web. Crear y mantener sitios web sin codigo. WordPress, Drupal, Joomla

Ejemplos:

- WordPress
- Drupal
- Joomla
- Vulnerabilidades si no actualizado
- Plugins riesgosos

Prioridad: MEDIA

CSP (Cloud Service Provider)

Definición: Proveedor de servicios cloud que ofrece infraestructura, plataforma o software en modelo serverless/cloud

Ejemplos:

- AWS
- Azure
- Google Cloud
- Gestiona infraestructura para serverless

Prioridad: MEDIA

CTR (Counter Mode)

Definición: Modo cifrado que convierte block cipher en stream cipher. Usa contador + IV. Paralelizable. No padding

Ejemplos:

- AES-CTR
- Paralelizable (rapido)
- No padding needed
- GCM usa CTR
- Nonce/counter unico critico

Prioridad: MEDIA

Clearance Levels

Definición: Niveles de autorizacion de seguridad. Clasificacion jerarquica. Gobierno/militar. Sujeto debe tener clearance >= clasificacion objeto

Ejemplos:

- Top Secret
- Secret
- Confidential
- Unclassified
- Need-to-know
- Modelo Bell-LaPadula

Prioridad: MEDIA

IaaS (Infrastructure as a Service)

Definición: Modelo cloud que proporciona infraestructura virtualizada. Usuario gestiona OS, aplicaciones. Proveedor gestiona hardware

Ejemplos:

- AWS EC2
- Azure Virtual Machines
- Google Compute Engine

Prioridad: ALTA

PaaS (Platform as a Service)

Definición: Plataforma de desarrollo en cloud. Proveedor gestiona OS y runtime. Usuario solo desarrolla aplicación

Ejemplos:

- Heroku
- Google App Engine
- Azure App Service

Prioridad: MEDIA

SaaS (Software as a Service)

Definición: Aplicación completa en cloud. Usuario solo consume el servicio. Proveedor gestiona todo

Ejemplos:

- Office 365
- Salesforce
- Gmail
- Dropbox

Prioridad: ALTA

Cold Site (Sitio Frio)

Definición: Sitio DR solo con espacio fisico y servicios basicos. Sin equipos preinstalados. RTO largo (dias/semanas). Opcion mas economica

Ejemplos:

- Solo edificio + electricidad + Internet
- RTO > 1 semana
- Envio e instalacion equipos necesario
- Minimo costo

Prioridad: ALTA

Containerización

Definición: Empaquetar aplicación y dependencias en unidad autocontenida (container) que corre aislada. Más ligero que VM

Ejemplos:

- Docker
- Kubernetes
- Microservicios en containers
- Aislamiento de aplicaciones

Prioridad: MEDIA

DAC (Discretionary Access Control)

Definición: Control de acceso discrecional. Propietario del recurso decide permisos. Usuarios pueden compartir recursos. Menos restrictivo

Ejemplos:

- Permisos NTFS en Windows
- chmod en Linux
- Usuario puede dar permisos a otros
- ACL definidas por owner

Prioridad: ALTA

DLP (Data Loss Prevention)

Definición: Sistema que detecta y previene exfiltración/fuga de datos sensibles. Monitoriza datos en reposo, uso y tránsito

Ejemplos:

- Bloquear email con números de tarjetas
- Alertar si copian PII a USB
- Detectar subida de datos confidenciales a cloud

Prioridad: ALTA

DMZ (Demilitarized Zone)

Definición: Segmento de red aislado entre Internet y red interna. Aloja servicios públicos (web, email) accesibles desde exterior

Ejemplos:

- Servidor web público en DMZ
- Firewall entre Internet-DMZ y DMZ-LAN

Prioridad: ALTA

DNS Filtering

Definición: Bloquear resoluciones DNS de dominios maliciosos. Previene acceso a phishing, malware, C&C.; Nivel de red

Ejemplos:

- Cisco Umbrella
- Quad9 (9.9.9.9)
- Bloquear malware.com devolviendo NXDOMAIN o IP de bloqueo

Prioridad: ALTA

Data Masking (Enmascaramiento de datos)

Definición: Ocultar datos sensibles reemplazandolos con caracteres. Protege datos en pantalla. No modifica datos originales en BD

Ejemplos:

- ****1234 (numero tarjeta)
- Asteriscos en password field
- XXX-XX-1234 (SSN)
- Ocultar PII en UI

Prioridad: MEDIA

Data Retention Policy (Politica de Retencion de Datos)

Definición: Politica que especifica cuanto tiempo retener datos antes de eliminarlos. Requisitos legales y compliance. Ciclo de vida de datos

Ejemplos:

- Emails: 7 años
- Logs: 90 dias
- Backups: 30 dias
- Compliance GDPR, HIPAA
- Legal hold exceptions

Prioridad: ALTA

Degaussing (Desmagnetizacion)

Definición: Eliminacion de datos mediante desmagnetizacion de medios magneticos. Campo magnetico fuerte borra datos. Destruye disco para reutilizacion

Ejemplos:

- Degausser para HDDs
- Desmagnetizador cintas magneticas
- Inutiliza disco tras proceso
- NO funciona en SSD

Prioridad: MEDIA

Dual Power Supply

Definición: Servidor con dos fuentes de alimentación redundantes. Tolerancia a fallo de PSU

Ejemplos:

- Servidor con 2 PSU a circuitos diferentes
- Si una falla, otra mantiene servidor

Prioridad: COMPLEMENTARIO

EAP-TLS

Definición: EAP Transport Layer Security. Metodo mas seguro 802.1X. Requiere certificados en cliente Y servidor. Mutual authentication

Ejemplos:

- WPA2-Enterprise mas seguro
- Certificado digital cliente
- PKI requerida
- No transmite contraseñas

Prioridad: ALTA

EAP-TTLS

Definición: EAP Tunneled TLS. Similar a PEAP pero mas flexible. Tunel TLS para autenticacion. Soporta metodos legacy dentro de tunel

Ejemplos:

- EAP-TTLS/PAP
- Certificado solo en servidor
- Alternativa a PEAP
- Mayor compatibilidad que PEAP

Prioridad: MEDIA

ECB (Electronic Codebook)

Definición: Modo cifrado de bloques MAS DEBIL. Cada bloque cifrado independiente. Patrones visibles. NO USAR

Ejemplos:

- AES-ECB (INSEGURO)
- Bloques identicos = cifrado identico
- Patrones visibles en imagenes
- NUNCA usar en produccion

Prioridad: ALTA

EDR (Endpoint Detection and Response)

Definición: Solución que detecta amenazas en endpoints por comportamiento. Permite investigación forense y respuesta remota

Ejemplos:

- CrowdStrike Falcon
- SentinelOne
- Detección de ransomware por comportamiento anómalo

Prioridad: ALTA

EFS (Encrypting File System)

Definición: Sistema de cifrado de archivos de Windows. Cifrado a nivel de archivo/carpeta. Transparente para usuario. Basado en certificados usuario

Ejemplos:

- Cifrar carpeta Mis Documentos
- EFS en NTFS
- Certificado usuario para clave
- Data at rest encryption

Prioridad: MEDIA

ESP (Encapsulating Security Payload)

Definición: Componente de IPSec que proporciona CONFIDENCIALIDAD (cifrado), integridad y autenticación del payload

Ejemplos:

- ESP en modo túnel cifra todo el paquete IP
- Protocolo 50

Prioridad: MEDIA

FIM (File Integrity Monitoring)

Definición: Monitoreo de cambios en archivos criticos. Detecta modificaciones no autorizadas. Hash baseline + comparacion. Alerta cambios sospechosos

Ejemplos:

- Tripwire
- OSSEC FIM
- Detecta cambio en /etc/passwd
- PCI DSS requirement 11.5
- Hash comparison

Prioridad: ALTA

Firewall

Definición: Dispositivo o software que filtra tráfico de red según reglas. Tipos: filtrado de paquetes, stateful, capa de aplicación (L7), NGFW

Ejemplos:

- Bloquear puerto 23 (Telnet)
- Permitir HTTP/HTTPS saliente
- Palo Alto NGFW con inspección deep packet

Prioridad: ALTA

Implicit Deny (Firewall)

Definición: Regla por defecto: denegar todo trafico no explicitamente permitido. Ultima regla implicita en ACLs

Ejemplos:

- ACL: permit tcp any any eq 443; permit tcp any any eq 80; [implicit deny all]
- Principio de minimo privilegio en firewalls

Prioridad: ALTA

Full Tunnel VPN

Definición: TODO el tráfico pasa por VPN, incluso Internet. Más seguro pero consume más ancho de banda corporativo

Ejemplos:

- Todo el tráfico inspeccionado por firewall corporativo
- Más control de seguridad

Prioridad: MEDIA

GDPR (General Data Protection Regulation)

Definición: Reglamento UE de proteccion de datos personales. Derecho privacidad ciudadanos UE. Multas severas por incumplimiento. RGPD en español

Ejemplos:

- Right to be forgotten
- Data breach notification 72h
- Consent requirement
- Multas hasta 4% revenue

Prioridad: ALTA

GRE (Generic Routing Encapsulation)

Definición: Protocolo tunelizacion Cisco. Encapsula diversos protocolos de capa 3. VPN site-to-site. NO cifra (usar con IPsec)

Ejemplos:

- GRE tunnel Cisco
- Encapsula IP, IPv6, IPX
- GRE over IPsec para cifrado
- IP protocol 47

Prioridad: MEDIA

Geofencing

Definición: Perimetro virtual geografico. Reglas basadas en ubicacion GPS. Permite/bloquea acceso segun localizacion. Control de acceso contextual

Ejemplos:

- Acceso solo desde oficina
- Bloquear login fuera del pais
- MDM geofencing
- Alertas salida de zona

Prioridad: MEDIA

Group Policy (GPO)

Definición: Configuracion centralizada en Active Directory para controlar usuarios/computadoras Windows. Politicas de seguridad, software, scripts

Ejemplos:

- Politica de contraseñas para dominio
- Desplegar software via GPO
- Configurar firewall de Windows
- Deshabilitar USB

Prioridad: ALTA

HIDS (Host-based IDS)

Definición: IDS instalado en host individual. Monitoriza logs, filesystem, procesos del sistema local

Ejemplos:

- OSSEC
- Detecta cambios no autorizados en archivos de sistema

Prioridad: MEDIA

HIPS (Host-based Intrusion Prevention System)

Definición: IPS instalado en host individual. Monitorea y bloquea actividad maliciosa en sistema. Respuesta activa a amenazas locales

Ejemplos:

- Bloquea exploit en endpoint
- Monitoreo system calls
- Previene buffer overflow
- Complementa antivirus

Prioridad: ALTA

Honeynet

Definición: Red de honeypots interconectados. Simula red completa de organizacion. Atrae atacantes para estudiar TTPs. Investigacion de amenazas

Ejemplos:

- Red falsa con servidores, workstations, routers falsos
- Monitoreo completo de ataques
- Research de malware

Prioridad: MEDIA

Honeytoken

Definición: Dato falso usado como trampa. Alerta cuando se accede. Credenciales falsas, archivos señuelo. Deteccion de breach

Ejemplos:

- Credenciales falsas en archivo
- Entrada DB ficticia
- Fake API key
- Email señuelo
- Alerta si se usa

Prioridad: MEDIA

Hot Site

Definición: Centro de datos de backup completamente operacional con replicación en tiempo real. RTO/RPO mínimos (minutos). MUY costoso

Ejemplos:

- Failover automático en minutos
- Sistema crítico 24/7
- Replicación síncrona de datos

Prioridad: ALTA

Hybrid Cloud

Definición: Combinación de cloud público, privado y/o on-premises. Datos/apps pueden moverse entre entornos

Ejemplos:

- Datos sensibles on-prem, aplicaciones en public cloud
- Burst a cloud en picos de demanda

Prioridad: MEDIA

IDS (Intrusion Detection System)

Definición: Sistema que DETECTA intrusiones pero NO bloquea. Genera alertas. Tipos: NIDS (red), HIDS (host)

Ejemplos:

- Snort en modo IDS
- Detección de escaneo de puertos
- Alerta de tráfico C2

Prioridad: ALTA

IEEE 802.1X

Definición: Estandar de control de acceso de red basado en puerto. Autenticacion antes de acceso a red. Usa EAP. Supplicant-Authenticator-Auth Server

Ejemplos:

- WPA2-Enterprise
- EAP-TLS autenticacion
- RADIUS backend
- Switch port authentication
- NAC enforcement

Prioridad: ALTA

IKE (Internet Key Exchange)

Definición: Protocolo para establecer conexión segura e intercambiar claves en IPSec VPN. Fase 1: autenticación, Fase 2: negociación de claves de sesión

Ejemplos:

- IKEv2 más rápido y seguro que IKEv1
- Establecer SA (Security Association) en IPSec

Prioridad: MEDIA

IMAPS (IMAP over SSL/TLS)

Definición: Protocolo de email cifrado. Puerto 993/TCP. IMAP con capa SSL/TLS para confidencialidad

Ejemplos:

- Configurar cliente email con IMAPS puerto 993
- Alternativa segura a IMAP puerto 143
- Cifrado de credenciales y emails

Prioridad: MEDIA

IPS (Intrusion Prevention System)

Definición: Sistema que DETECTA Y BLOQUEA intrusiones en línea (inline). IDS + prevención activa

Ejemplos:

- Snort en modo IPS
- Bloqueo automático de IP atacante
- Drop de paquetes maliciosos

Prioridad: ALTA

IPSec

Definición: Suite de protocolos para VPN a nivel IP. Modos: transporte (solo payload), túnel (paquete completo). Componentes: AH (autenticación), ESP (cifrado)

Ejemplos:

- Site-to-site VPN corporativa
- IKE para negociación de claves
- ESP para confidencialidad

Prioridad: MEDIA

IPSec Transport Mode

Definición: Modo IPSec que cifra SOLO el payload (datos), NO el header IP. Usado para host-to-host

Ejemplos:

- Comunicación cifrada entre dos servidores
- Header IP visible

Prioridad: COMPLEMENTARIO

IPSec Tunnel Mode

Definición: Modo IPSec que cifra TODO el paquete original (header + payload) y añade nuevo header IP. Usado en VPN site-to-site

Ejemplos:

- VPN entre oficinas
- Paquete completo protegido

Prioridad: MEDIA

IPsec (IP Security)

Definición: Suite de protocolos para seguridad IP. Cifrado, autenticacion e integridad. VPNs site-to-site. Layer 3 del modelo OSI

Ejemplos:

- VPN IPsec
- AH (Authentication Header)
- ESP (Encapsulating Security Payload)
- IKE (Internet Key Exchange)

Prioridad: ALTA

IPsec Transport Mode

Definición: Modo IPsec que cifra solo payload (datos). Header IP original sin cifrar. Usado host-to-host. Menos overhead que Tunnel

Ejemplos:

- Comunicacion host a host
- No modifica IP header
- ESP transport
- Menor overhead que tunnel mode

Prioridad: MEDIA

Implicit Deny (Denegación Implícita)

Definición: Regla por defecto en ACL/firewall: denegar TODO lo que no esté explícitamente permitido. Principio de seguridad

Ejemplos:

- Última regla invisible: deny any any
- Whitelist approach
- Más seguro que permit by default

Prioridad: MEDIA

Journaling (Llevar un diario)

Definición: Registro de cambios antes de aplicarlos. Filesystem journaling. Recuperacion tras crash. Integridad de datos garantizada

Ejemplos:

- ext4 journal
- NTFS journal
- Database WAL
- Previene corrupcion tras fallo

Prioridad: MEDIA

Layer 7 Firewall (Application Layer Firewall)

Definición: Firewall que inspecciona capa de aplicacion OSI. Analiza contenido payload (no solo headers). Filtrado profundo pero mas lento

Ejemplos:

- WAF (Web Application Firewall)
- Inspecciona HTTP payload
- Bloquea SQL injection
- Mas lento que Layer 3/4

Prioridad: ALTA

Least Privilege

Definición: Principio de minimo privilegio. Usuarios/procesos solo acceso necesario para tarea. Reduce superficie de ataque. Best practice seguridad

Ejemplos:

- Usuario sin admin rights
- Cuenta servicio limitada
- Just-in-time admin access
- Reduce impacto de compromiso

Prioridad: ALTA

Load Balancing

Definición: Distribución de carga de trabajo entre múltiples servidores para mejorar rendimiento y disponibilidad

Ejemplos:

- HAProxy
- F5 BigIP
- Round-robin, least connections
- Distribución de tráfico web entre servidores

Prioridad: ALTA

MAC (Mandatory Access Control)

Definición: Control de acceso basado en clasificacion de seguridad. Sistema operativo impone politicas. Usuario NO puede modificar permisos

Ejemplos:

- SELinux
- AppArmor
- Etiquetas: Top Secret, Secret, Confidential, Unclassified
- Usado en entornos militares/gubernamentales

Prioridad: ALTA

MTBF (Mean Time Between Failures)

Definición: Tiempo promedio entre fallos de un componente. Métrica de fiabilidad

Ejemplos:

- Disco duro con MTBF de 1,000,000 horas
- Mayor MTBF = más fiable

Prioridad: COMPLEMENTARIO

MTTR (Mean Time to Repair)

Definición: Tiempo promedio para reparar componente tras fallo. Métrica de mantenibilidad

Ejemplos:

- MTTR de 2 horas para servidores críticos
- Menor MTTR = recuperación más rápida

Prioridad: COMPLEMENTARIO

Machine Language (Lenguaje Maquina)

Definición: Codigo binario ejecutable directamente por CPU. No legible por humanos. Nivel mas bajo de programacion. 0s y 1s

Ejemplos:

- 01001000 01100101
- Instrucciones CPU directas
- Compilado desde assembly
- Arquitectura especifica

Prioridad: COMPLEMENTARIO

NAC (Network Access Control)

Definición: Control de acceso a la red a nivel de puerto. Verifica cumplimiento de seguridad antes de permitir acceso. Protocolo: 802.1X

Ejemplos:

- Verificar antivirus actualizado antes de dar acceso
- BYOD con verificación de políticas
- Cisco ISE

Prioridad: MEDIA

NGFW (Next-Generation Firewall)

Definición: Firewall avanzado con deep packet inspection, IPS, application awareness, threat intelligence integrada

Ejemplos:

- Palo Alto Networks
- Bloquear Facebook pero permitir LinkedIn
- Inspección SSL/TLS

Prioridad: ALTA

NIDS (Network-based IDS)

Definición: Sistema de deteccion de intrusiones a nivel de red. Monitorea trafico sin bloquearlo. Modo pasivo. Genera alertas

Ejemplos:

- Snort en modo IDS
- Monitoreo de span port
- Deteccion de escaneos y ataques
- NO bloquea - solo alerta

Prioridad: ALTA

NIPS (Network-based IPS)

Definición: Sistema de prevencion de intrusiones a nivel de red. Modo inline - puede bloquear trafico. Accion proactiva

Ejemplos:

- Snort en modo IPS
- Inline entre segmentos
- Bloquea ataques automaticamente
- Drop packets maliciosos

Prioridad: ALTA

Network Tap

Definición: Dispositivo hardware que copia tráfico de red de forma pasiva. Más confiable que port mirroring para monitorización

Ejemplos:

- Tap en cable de fibra
- Monitorización de red sin afectar rendimiento
- IDS/SIEM conectado a tap

Prioridad: COMPLEMENTARIO

Non-Persistent VDI

Definición: VDI que resetea a estado original tras cada sesion. Escritorio compartido entre usuarios. No guarda cambios. Mas seguro

Ejemplos:

- Escritorio reset al logout
- Comparte golden image
- Mas economico que persistent
- Ideal para task workers

Prioridad: MEDIA

PAC (Proxy Auto-Configuration)

Definición: Archivo script que define como navegadores seleccionan proxy. Reglas automaticas de enrutamiento web. Formato JavaScript

Ejemplos:

- proxy.pac file
- function FindProxyForURL()
- DIRECT vs PROXY rules
- Automatic proxy selection

Prioridad: MEDIA

PDU (Power Distribution Unit)

Definición: Dispositivo que distribuye electricidad a múltiples equipos en rack. Puede monitorizar consumo

Ejemplos:

- Regleta inteligente de rack
- PDU con gestión remota
- Monitorización de consumo por puerto

Prioridad: COMPLEMENTARIO

PEAP (Protected EAP)

Definición: Protocolo de autenticacion 802.1X. Crea tunel TLS antes de autenticar. Protege credenciales. EAP dentro de TLS

Ejemplos:

- PEAP-MSCHAPv2 (Windows)
- WPA2-Enterprise
- RADIUS + PEAP
- Certificado servidor RADIUS
- Tunel TLS cifrado

Prioridad: ALTA

POP3S (POP3 over SSL/TLS)

Definición: Protocolo de email cifrado. Puerto 995/TCP. POP3 con capa SSL/TLS

Ejemplos:

- Puerto 995 vs POP3 puerto 110
- Descarga de emails con cifrado
- Menos usado que IMAPS

Prioridad: MEDIA

PSK (Pre-Shared Key)

Definición: Clave secreta compartida previamente entre partes. Usado en WPA/WPA2-Personal. Autenticacion simetrica. Mas simple que 802.1X

Ejemplos:

- Contraseña WiFi casera
- WPA2-Personal
- WPA3-Personal SAE
- IPsec PSK authentication

Prioridad: ALTA

Port Mirroring (Duplicacion de puertos)

Definición: Copia trafico de puerto(s) a puerto monitor. Permite analisis pasivo de red. SPAN port. Usado para IDS, analisis trafico

Ejemplos:

- SPAN port en Cisco
- Mirror port 1-10 to port 24
- IDS monitoring
- Packet capture sin interrupcion

Prioridad: MEDIA

Proxy Server (Servidor Proxy)

Definición: Intermediario entre cliente e Internet. Filtra, cachea y anonimiza trafico. Forward o reverse proxy. Control y seguridad

Ejemplos:

- Squid proxy
- Web proxy
- Forward proxy (salida)
- Reverse proxy (entrada)
- Content filtering

Prioridad: ALTA

RAID (Redundant Array of Independent Disks)

Definición: Configuración de múltiples discos para redundancia y/o rendimiento. Niveles: 0 (striping), 1 (mirroring), 5 (striping + paridad), 10 (mirror + stripe)

Ejemplos:

- RAID 0: rendimiento, NO redundancia
- RAID 1: espejo para tolerancia a fallos
- RAID 5: balance rendimiento/redundancia (mín 3 discos)
- RAID 10: máximo rendimiento y redundancia (mín 4 discos)

Prioridad: MEDIA

RAS (Remote Access Service)

Definición: Servicio que proporciona acceso remoto seguro a red. VPN, dial-up, terminal services. Permite trabajo remoto

Ejemplos:

- Windows RAS
- VPN concentrator
- Remote Desktop Gateway
- Acceso remoto empleados

Prioridad: ALTA

RPO (Recovery Point Objective)

Definición: Cantidad máxima aceptable de pérdida de datos medida en tiempo. Cuánto dato puedes perder

Ejemplos:

- RPO de 1 hora = backups cada hora máximo
- RPO = 0 → replicación síncrona en tiempo real

Prioridad: ALTA

RTO (Recovery Time Objective)

Definición: Tiempo máximo aceptable de inactividad de un sistema tras un desastre. Cuánto tiempo puede estar caído

Ejemplos:

- RTO de 4 horas para sistema crítico
- Si RTO = 1 hora → necesitas hot site

Prioridad: ALTA

Remote Access VPN (Client-to-Site)

Definición: VPN para usuarios individuales que conectan a red corporativa desde ubicación remota. Requiere cliente VPN

Ejemplos:

- Teletrabajo con cliente OpenVPN
- SSL VPN via navegador

Prioridad: MEDIA

Remote Wipe (Borrado Remoto)

Definición: Borrado remoto de datos en dispositivo movil perdido/robado. MDM feature. Protege datos corporativos. Factory reset remoto

Ejemplos:

- MDM remote wipe
- Find My iPhone erase
- Android Device Manager wipe
- Proteccion tras robo

Prioridad: ALTA

Replication (Replicacion)

Definición: Copia continua de datos a ubicacion secundaria. Sincrona (RPO=0) o asincrona (RPO>0). Alta disponibilidad y DR

Ejemplos:

- Database replication
- Storage replication
- Active-Passive replica
- Replicacion sincrona cara pero RPO=0

Prioridad: ALTA

RuBAC (Rule-Based Access Control)

Definición: Control de acceso basado en reglas. Combina multiples condiciones: tiempo, ubicacion, tipo de dispositivo, etc.

Ejemplos:

- Permitir acceso solo de 8am-6pm
- Bloquear acceso desde IPs fuera del pais
- ACLs de firewall son tipo RuBAC

Prioridad: MEDIA

SASE (Secure Access Service Edge)

Definición: Framework Gartner. Red + seguridad en servicio cloud unico. SD-WAN + CASB + FWaaS + ZTNA + SWG. Cloud-native

Ejemplos:

- Gartner framework
- Convergencia red + seguridad
- Replace MPLS + VPN
- Cloud-delivered security
- Zero Trust Network Access

Prioridad: ALTA

SDN (Software-Defined Networking)

Definición: Red definida por software. Separa plano de control de plano de datos. Gestion centralizada via controlador. Programable y flexible

Ejemplos:

- OpenFlow protocol
- Controlador SDN centralizado
- Network automation
- Dynamic policy enforcement

Prioridad: ALTA

SD-WAN (Software-Defined WAN)

Definición: Red WAN definida por software que simplifica gestión y permite usar múltiples tipos de conexión (MPLS, Internet, LTE)

Ejemplos:

- Optimizar tráfico entre sucursales
- Failover automático entre conexiones
- Gestión centralizada

Prioridad: COMPLEMENTARIO

SELinux (Security-Enhanced Linux)

Definición: Implementacion de Mandatory Access Control (MAC) en Linux. Politicas de seguridad a nivel kernel. Confina procesos

Ejemplos:

- Modos: Enforcing (bloquea), Permissive (alerta), Disabled
- Contextos de seguridad en archivos/procesos
- Politicas targeted/strict

Prioridad: MEDIA

SHTTP (Secure HTTP)

Definición: Protocolo obsoleto para datos seguros web. DEPRECATED. Reemplazado por HTTPS. No confundir con HTTPS

Ejemplos:

- Obsoleto desde 1990s
- Reemplazado por HTTPS/TLS
- NO es lo mismo que HTTPS
- RFC 2660

Prioridad: COMPLEMENTARIO

SIEM (Security Information and Event Management)

Definición: Plataforma centralizada que recopila, correlaciona y analiza logs de múltiples fuentes. Genera alertas de seguridad

Ejemplos:

- Splunk
- Elastic Security
- QRadar
- Correlación: 1000 login fallidos en 1 min = brute force

Prioridad: ALTA

SMTPS (SMTP Secure)

Definición: SMTP sobre SSL/TLS implícito. Puerto 465. Deprecated en favor de STARTTLS. Cifrado desde inicio conexion

Ejemplos:

- Puerto 465
- SSL/TLS desde inicio
- Deprecated (usar STARTTLS)
- Cifrado email submission

Prioridad: MEDIA

SNMP (Simple Network Management Protocol)

Definición: Protocolo para gestionar y monitorizar dispositivos de red. Versiones: v1/v2c (inseguras), v3 (cifrada)

Ejemplos:

- Monitorizar CPU/memoria de router
- SNMPv3 con autenticación
- Puerto 161/162

Prioridad: MEDIA

SOAR (Security Orchestration, Automation and Response)

Definición: Plataforma que automatiza respuesta a incidentes mediante playbooks. Orquesta múltiples herramientas de seguridad

Ejemplos:

- Playbook de phishing: detectar → cuarentenar email → bloquear dominio → notificar usuario
- Cortex XSOAR, Splunk Phantom

Prioridad: MEDIA

SOW (Statement of Work)

Definición: Declaracion de trabajo detallada. Describe trabajo a realizar en proyecto. Alcance, entregables, timeline, costo

Ejemplos:

- SOW bajo MSA
- Define entregables especificos
- Proyecto pentest SOW
- Alcance y precio detallados

Prioridad: ALTA

SSL VPN

Definición: VPN basada en SSL/TLS. Acceso mediante navegador web (clientless) o cliente ligero. Más fácil de usar que IPSec para usuarios remotos

Ejemplos:

- Acceso remoto sin cliente dedicado
- Portal web corporativo seguro
- Cisco AnyConnect

Prioridad: MEDIA

STARTTLS

Definición: Comando para upgradear conexion plaintext a TLS. Usado en SMTP, IMAP, POP3. Explicit TLS. Puerto estandar + upgrade

Ejemplos:

- SMTP puerto 587 + STARTTLS
- Upgrade conexion a TLS
- Mejor que SMTPS deprecated
- Fallback a plaintext posible

Prioridad: ALTA

SWG (Secure Web Gateway)

Definición: Proxy avanzado que filtra tráfico web malicioso. Protege navegación: anti-malware, filtrado URL, DLP, inspección SSL

Ejemplos:

- Zscaler
- Filtrar categorías de sitios
- Bloquear descarga de malware
- Cloud-based proxy

Prioridad: MEDIA

Sandboxing

Definición: Entorno aislado para ejecutar código sospechoso sin riesgo para sistema principal. Análisis seguro de malware

Ejemplos:

- Ejecutar archivo sospechoso en VM desechable
- Cuckoo Sandbox
- Navegador en sandbox

Prioridad: MEDIA

Screened Subnet (DMZ)

Definición: Subred ligeramente protegida entre Internet y red interna. Servidores publicos en DMZ. Doble firewall tipico. Buffer zone de seguridad

Ejemplos:

- Web servers en DMZ
- Email relay en DMZ
- Firewall Internet-DMZ-LAN
- Dual firewall architecture

Prioridad: ALTA

Secure Baseline (Linea de Base Segura)

Definición: Configuracion estandar de seguridad minima. Template de hardening. Configuraciones y ajustes fundamentales. Punto de partida seguro

Ejemplos:

- CIS Benchmarks
- DISA STIGs
- Windows Security Baseline
- Disable unnecessary services
- Strong passwords

Prioridad: ALTA

Simulation (Ejercicio de simulación)

Definición: Ejercicio realista que simula ataque real para probar respuesta. Más completo que tabletop

Ejemplos:

- Simular phishing real
- Red team vs Blue team
- Ejecutar acciones de respuesta

Prioridad: MEDIA

Site-to-Site VPN

Definición: VPN que conecta dos redes completas. Tipicamente entre oficinas. Gateway VPN en cada lado. IPsec comun. Always-on

Ejemplos:

- Oficina central a sucursal
- IPsec site-to-site
- Router VPN endpoints
- Conecta LANs completas

Prioridad: ALTA

Snapshot (Instantanea)

Definición: Captura punto-en-tiempo de VM o volumen. Estado completo en momento especifico. Rollback rapido. NO es backup completo a largo plazo

Ejemplos:

- VMware snapshot antes de update
- AWS EBS snapshot
- Rollback en minutos
- No reemplaza backups

Prioridad: ALTA

Split Tunnel VPN

Definición: VPN que permite tráfico simultáneo por VPN (corporativo) y directo a Internet (no corporativo). Ahorra ancho de banda pero menos seguro

Ejemplos:

- Tráfico a red corporativa via VPN, Netflix directo a Internet
- Conserva bandwidth de empresa

Prioridad: MEDIA

Split Tunneling

Definición: VPN que permite trafico simultaneo por VPN y red publica. Trafico corporativo via VPN, Internet directo. Ahorra ancho de banda

Ejemplos:

- Acceso recursos empresa via VPN, Netflix via ISP
- Reduce latencia Internet
- Riesgo: bypass VPN security

Prioridad: MEDIA

TKIP (Temporal Key Integrity Protocol)

Definición: Protocolo seguridad WPA1. Mejora WEP. Claves temporales por paquete. Obsoleto (usar CCMP/WPA2)

Ejemplos:

- WPA con TKIP
- Mejor que WEP pero obsoleto
- Vulnerabilidades conocidas
- Usar WPA2/CCMP

Prioridad: MEDIA

Tabletop Exercise

Definición: Simulacro de mesa donde equipo discute respuesta a escenario hipotético de incidente. NO es práctica real

Ejemplos:

- Discutir qué hacer ante ransomware
- Revisión de IRP sin ejecutar acciones
- Identificar gaps en procedimientos

Prioridad: MEDIA

Time-of-Day Restrictions

Definición: Limitar acceso a sistemas/recursos basado en horario. Parte de RuBAC

Ejemplos:

- Acceso a sistema nominas solo 8am-6pm
- Deshabilitar cuentas fuera de horario laboral
- GPO con restricciones horarias

Prioridad: MEDIA

UPS (Uninterruptible Power Supply)

Definición: Sistema de alimentación ininterrumpida. Batería que proporciona energía temporal durante corte eléctrico

Ejemplos:

- UPS de 10 min para apagado seguro
- UPS enterprise para mantener datacenter hasta generador arranca

Prioridad: ALTA

URL Scanning

Definición: Analisis de URLs en tiempo real para detectar phishing, malware, sitios maliciosos. Reputacion de dominios

Ejemplos:

- Bloquear URLs de phishing
- Categorizar sitios web (social media, gambling)
- Servicios: Google Safe Browsing, VirusTotal

Prioridad: ALTA

UTM (Unified Threat Management)

Definición: Dispositivo all-in-one que combina firewall, IPS, antivirus, anti-spam, VPN, filtrado web en una sola solución

Ejemplos:

- Fortinet FortiGate
- Sophos UTM
- Seguridad completa para PYMES

Prioridad: MEDIA

VDI (Virtual Desktop Infrastructure)

Definición: Escritorios virtuales centralizados. Usuario accede a escritorio Windows/Linux desde thin client o navegador

Ejemplos:

- VMware Horizon
- Citrix Virtual Apps and Desktops
- Azure Virtual Desktop
- BYOD accediendo a escritorio corporativo

Prioridad: COMPLEMENTARIO

VLAN (Virtual Local Area Network)

Definición: Segmentacion logica de red. Divide red fisica en multiples redes virtuales. Aislamiento de broadcast. Seguridad por segmentacion

Ejemplos:

- VLAN 10 = Contabilidad
- VLAN 20 = IT
- VLAN tagging 802.1Q
- Trunk port
- Access port

Prioridad: ALTA

VLSM (Variable Length Subnet Mask)

Definición: Subredes de diferentes tamaños en misma red. Uso eficiente de IPs. Permite subnetting flexible. Optimiza espacio de direcciones

Ejemplos:

- /24 para usuarios (254 hosts)
- /30 para enlaces punto-a-punto (2 hosts)
- Subnetting eficiente

Prioridad: MEDIA

VPC (Virtual Private Cloud)

Definición: Red privada virtual aislada dentro de cloud público. Control completo sobre red (subnets, routing, gateways)

Ejemplos:

- AWS VPC
- Azure Virtual Network
- Segmentación lógica en cloud

Prioridad: MEDIA

VPN (Virtual Private Network)

Definición: Túnel cifrado sobre red pública. Conecta sitios remotos o usuarios de forma segura. Protocolos: IPSec, SSL/TLS, WireGuard

Ejemplos:

- Empleado remoto conecta a red corporativa
- Site-to-site VPN entre oficinas
- OpenVPN, WireGuard

Prioridad: ALTA

VTC (Video Teleconferencing)

Definición: Videoconferencia en tiempo real. Audio y video simultaneo entre individuos o grupos. Zoom, Teams, WebEx

Ejemplos:

- Zoom meetings
- Microsoft Teams
- Cisco WebEx
- Google Meet
- Require encryption (TLS)

Prioridad: COMPLEMENTARIO

Virtualización

Definición: Ejecutar múltiples sistemas operativos virtuales (VMs) en un host físico mediante hypervisor

Ejemplos:

- VMware ESXi
- Hyper-V
- VirtualBox
- Consolidación de servidores

Prioridad: MEDIA

WAF (Web Application Firewall)

Definición: Firewall específico para proteger aplicaciones web. Filtra tráfico HTTP/HTTPS. Protege contra SQLi, XSS, CSRF

Ejemplos:

- Cloudflare WAF
- AWS WAF
- ModSecurity

Prioridad: ALTA

WIDS (Wireless IDS)

Definición: IDS específico para redes WiFi. Detecta rogue APs, ataques de deauth, evil twins, accesos no autorizados

Ejemplos:

- Detectar AP no autorizado
- Alertar sobre ataque de deautenticación
- Aircrack-ng para análisis

Prioridad: COMPLEMENTARIO

WPA Enterprise

Definición: WPA/WPA2/WPA3 con autenticacion 802.1X. Servidor RADIUS. Credenciales individuales por usuario. Para empresas

Ejemplos:

- RADIUS server
- EAP-TLS
- PEAP-MSCHAPv2
- Credenciales AD
- Mas seguro que PSK

Prioridad: ALTA

Warm Site (Sitio Calido)

Definición: Sitio DR con infraestructura basica. Equipos instalados pero no completamente configurados. RTO medio (horas/dias). Balance costo/tiempo

Ejemplos:

- Servidores listos, datos desactualizados
- RTO 12-24 horas
- Requiere restore reciente
- Costo medio DR

Prioridad: ALTA

XDR (Extended Detection and Response)

Definición: Evolución de EDR que integra telemetría de múltiples fuentes (endpoint, red, cloud, email) para detección y respuesta unificada

Ejemplos:

- Correlación entre endpoint y red
- Detección multi-capa
- Palo Alto Cortex XDR

Prioridad: COMPLEMENTARIO

Dominio 4: Operaciones de Seguridad

Peso examen: 28% | Términos: 60

ABAC (Attribute-Based Access Control)

Definición: Control de acceso basado en atributos. Reglas granulares con multiples atributos: usuario, recurso, entorno. Muy flexible

Ejemplos:

- Acceso si: rol=manager AND dept=HR AND time=business_hours
- XACML
- Context-aware access
- Dynamic rules

Prioridad: MEDIA

ARO (Annualized Rate of Occurrence)

Definición: Frecuencia estimada anual de amenaza. Cuantas veces al año ocurre incidente. Calculo de riesgo: SLE x ARO = ALE

Ejemplos:

- Ransomware: ARO = 0.5 (cada 2 años)
- Inundacion: ARO = 0.1 (cada 10 años)
- ALE = SLE x ARO

Prioridad: MEDIA

AUP (Acceptable Use Policy)

Definición: Politica que define uso aceptable de recursos IT de organizacion. Control directivo que guia comportamiento de usuarios

Ejemplos:

- No uso personal de email corporativo
- Prohibir descarga de software no autorizado
- Politicas de redes sociales

Prioridad: ALTA

Active Reconnaissance

Definición: Reconocimiento activo. Interaccion directa con objetivo. Genera trafico detectable. Escaneos, sondeos

Ejemplos:

- Nmap port scan
- Vulnerability scan
- DNS zone transfer
- Banner grabbing
- MAS detectable que passive

Prioridad: ALTA

Automation (Security)

Definición: Automatizacion de tareas repetitivas de seguridad. Scripts, runbooks, respuestas automaticas. Reduce tiempo de respuesta

Ejemplos:

- Auto-bloqueo de IPs maliciosas
- Patch deployment automatico
- Respuesta automatica a incidentes
- Scripting con Python/PowerShell

Prioridad: ALTA

Biometrics (Biometria)

Definición: Autenticacion mediante caracteristicas biologicas o comportamentales. Huella, facial, iris, voz. Algo que eres

Ejemplos:

- Fingerprint scanner
- Face ID
- Iris scan
- Voice recognition
- Gait analysis
- FAR y FRR metrics

Prioridad: ALTA

Blue Team

Definición: Equipo de defensa. Detecta y responde a ataques. Monitoriza logs y alertas. Defiende contra Red Team

Ejemplos:

- SOC analysts
- SIEM monitoring
- Incident response
- Threat hunting
- Detectar ataques Red Team

Prioridad: ALTA

Bug Bounty

Definición: Programa de recompensas por descubrir vulnerabilidades. Researchers eticos reportan bugs a cambio de pago

Ejemplos:

- HackerOne
- Bugcrowd
- Programas de Google, Microsoft, Apple
- Responsible disclosure

Prioridad: MEDIA

CBC (Cipher Block Chaining)

Definición: Modo de cifrado de bloques que encadena bloques. Cada bloque cifrado depende del anterior. Usa IV (Initialization Vector)

Ejemplos:

- AES-CBC
- Requiere IV aleatorio
- Padding oracle attacks
- Cifrado secuencial (no paralelo)

Prioridad: MEDIA

CTR (Counter Mode)

Definición: Modo de cifrado que combina contador unico con clave para generar bloques pseudoaleatorios. Permite paralelizacion

Ejemplos:

- AES-CTR
- Cifrado paralelo
- Convierte block cipher en stream cipher
- No requiere padding

Prioridad: MEDIA

CVE (Common Vulnerabilities and Exposures)

Definición: Sistema de identificacion de vulnerabilidades publicas. ID unico CVE-YEAR-NUMBER. MITRE mantiene base de datos. Referencia estandar

Ejemplos:

- CVE-2021-44228 (Log4Shell)
- CVE-2014-0160 (Heartbleed)
- CVE database MITRE
- Referencia estandar industria

Prioridad: ALTA

Code Signing

Definición: Firma digital de codigo/software. Verifica autenticidad y integridad. Certificado del desarrollador. Previene modificacion maliciosa

Ejemplos:

- Certificado EV Code Signing
- Firma ejecutables .exe
- macOS Gatekeeper
- Windows SmartScreen
- Hash + firma privada

Prioridad: ALTA

Concurrent Session Usage

Definición: Indicador de compromiso. Mismo usuario logueado simultaneamente en multiples ubicaciones. Posible robo de credenciales

Ejemplos:

- Usuario en NYC y Tokyo simultaneamente
- Alerta SIEM sesion duplicada
- Indicador de account sharing o compromiso

Prioridad: MEDIA

DKIM (DomainKeys Identified Mail)

Definición: Autenticacion de email mediante firma digital. Verifica remitente y integridad mensaje. Clave privada firma, publica en DNS verifica

Ejemplos:

- DKIM-Signature header
- DNS TXT record con clave publica
- Previene email spoofing
- Parte de email authentication

Prioridad: ALTA

DLP (Data Loss Prevention)

Definición: Tecnologia para prevenir fuga de datos sensibles. Monitorea, detecta, bloquea transferencias no autorizadas. Network-based, Endpoint-based, Cloud-based

Ejemplos:

- Bloquear envio de datos PII por email
- Prevenir copia a USB
- Detectar subida de datos a Dropbox
- Politicas basadas en contenido/contexto

Prioridad: ALTA

DMARC (Domain-based Message Authentication, Reporting and Conformance)

Definición: Politica que especifica como manejar emails que fallan SPF/DKIM. Quarantine, Reject o None. Reportes de compliance

Ejemplos:

- DMARC DNS record
- p=reject (rechazar emails falsos)
- p=quarantine
- Reportes agregados RUA
- Combina SPF + DKIM

Prioridad: ALTA

Dark Web

Definición: Red overlay anonima (Tor, I2P). Requiere software especial. Usado para: anonimato, mercados ilegales, leaks de datos

Ejemplos:

- Tor Browser
- Dominios .onion
- Monitoreo de credenciales filtradas
- Threat intelligence de foros de hackers

Prioridad: MEDIA

Data Controller (Controlador de Datos / Responsable del Tratamiento)

Definición: Entidad que determina propositos y medios de procesamiento de datos personales. Responsabilidad principal GDPR. Decide QUE y COMO

Ejemplos:

- Empresa que recopila datos clientes
- Hospital con datos pacientes
- Determina retencion y uso de datos

Prioridad: MEDIA

Data Processor (Procesador de Datos)

Definición: Entidad que procesa datos personales en nombre del controlador. Sigue instrucciones del controlador. Responsabilidad compartida GDPR

Ejemplos:

- Cloud provider (AWS, Azure)
- Payroll service
- Email marketing platform
- Procesa datos segun instrucciones

Prioridad: MEDIA

Dynamic Code Analysis

Definición: Analisis de aplicacion en EJECUCION. Detecta vulnerabilidades en runtime. Parte de DAST

Ejemplos:

- Burp Suite
- OWASP ZAP
- Detecta: XSS, CSRF, autenticacion rota
- Fuzzing de inputs
- Testing en staging/QA

Prioridad: ALTA

E-Discovery (Electronic Discovery / Descubrimiento Electronico)

Definición: Identificar, recopilar y producir ESI (Electronically Stored Information) para litigio. Proceso legal forense digital

Ejemplos:

- Email discovery en lawsuit
- Forensic collection
- Legal hold
- Chain of custody
- Produccion de evidencia digital

Prioridad: MEDIA

Fuzzing

Definición: Tecnica de testing automatizada. Envia inputs invalidos/aleatorios/inesperados. Busca crashes o comportamiento anormal. Encuentra vulnerabilidades

Ejemplos:

- AFL fuzzer
- Peach Fuzzer
- Burp Intruder
- Descubrir buffer overflows
- Input malformado
- Mutation-based fuzzing

Prioridad: ALTA

Gray-Box Testing

Definición: Pentest con conocimiento parcial. Informacion limitada del sistema. Mezcla de black-box y white-box. Mas realista que white-box

Ejemplos:

- Credenciales de usuario normal
- Diagrama de red sin detalles
- Lista de IPs sin configuraciones
- Pentest semi-informado

Prioridad: ALTA

IRP (Incident Response Plan)

Definición: Plan documentado de respuesta a incidentes. Describe pasos en cada fase. Roles, responsabilidades, procedimientos. Playbooks

Ejemplos:

- Ransomware playbook
- Data breach response plan
- Contact escalation list
- IR phases documented

Prioridad: ALTA

Impossible Travel

Definición: Indicador de compromiso. Login desde ubicaciones geograficamente imposibles en tiempo corto. Usuario en Madrid y luego 1h despues en Tokio

Ejemplos:

- Login Paris 10am, luego Sydney 10:30am
- Azure AD Identity Protection
- Indicador robo de credenciales

Prioridad: ALTA

Incident Response - Containment, Eradication, Recovery

Definición: Tercera fase de IR. Contener amenaza, erradicar malware, recuperar sistemas. Limitar daño y restaurar operaciones

Ejemplos:

- Aislar sistema infectado
- Remove malware
- Restore from backup
- Patch vulnerabilities

Prioridad: ALTA

Incident Response - Detection and Analysis

Definición: Segunda fase de IR. Detectar e identificar incidentes. Analizar alcance, impacto y causa raiz. Determinar severidad

Ejemplos:

- SIEM alert
- Analizar logs
- Identificar IOC
- Determine scope
- Classify incident severity

Prioridad: ALTA

Incident Response - Post-Incident Activity

Definición: Cuarta fase de IR. Actividades tras incidente. Lessons learned, actualizar procedimientos, mejorar defensas. Documentacion

Ejemplos:

- Post-mortem meeting
- Update IR plan
- Document incident
- Improve detection rules
- Training updates

Prioridad: ALTA

Incident Response - Preparation

Definición: Primera fase de IR. Preparacion previa a incidentes. Crear plan IR, entrenar equipo, herramientas listas. Proactividad

Ejemplos:

- Crear IR plan
- Training SOC team
- Deploy SIEM
- Contact list
- Tabletop exercises

Prioridad: ALTA

IoC (Indicator of Compromise)

Definición: Evidencia forense de actividad maliciosa. Artefactos que indican breach o compromiso. Hash malware, IP C2, dominios maliciosos

Ejemplos:

- Hash MD5 de malware
- IP de C2 server
- Dominio malicioso
- Registry key sospechosa
- Unusual outbound traffic

Prioridad: ALTA

JSON (JavaScript Object Notation)

Definición: Formato ligero de intercambio de datos. Legible para humanos. Basado en sintaxis JavaScript. Alternativa a XML

Ejemplos:

- APIs REST
- Archivos de configuracion
- Mas simple que XML
- Pares clave-valor

Prioridad: MEDIA

MAC (Mandatory Access Control)

Definición: Control de acceso obligatorio. Sistema operativo impone politica. Basado en clasificacion y clearance. Usado en entornos militares/gobierno

Ejemplos:

- SELinux
- Clearance: Top Secret, Secret
- Labels en objetos
- No discretion del usuario
- Bell-LaPadula model

Prioridad: MEDIA

MDM (Mobile Device Management)

Definición: Gestion centralizada de dispositivos moviles. Control configuracion, seguridad, apps. Remote wipe. Enforce policies

Ejemplos:

- Intune
- MobileIron
- AirWatch
- Remote wipe
- App whitelist/blacklist
- Enforce encryption
- BYOD management

Prioridad: ALTA

Metadata (Metadatos)

Definición: Datos que describen otros datos. Info sobre archivo sin ser contenido. Autor, fecha creacion, modificacion, ubicacion GPS en fotos

Ejemplos:

- EXIF en fotos (GPS, camara)
- Autor documento Word
- Email headers
- Timestamp archivos
- HTML meta tags

Prioridad: MEDIA

Missing Logs

Definición: Indicador de compromiso. Ausencia o borrado de logs. Atacantes eliminan evidencia. Gap en logs de auditoria

Ejemplos:

- Atacante ejecuta wevtutil cl Security
- Gap de 3 horas en logs
- Log tampering
- Indicador anti-forensics

Prioridad: ALTA

Normalization

Definición: Proceso de convertir datos a formato estandar. En SIEM: unificar logs de multiples fuentes. Facilita correlacion y analisis

Ejemplos:

- Timestamp en UTC
- IP en formato estandar
- Campos comunes (src_ip, dst_ip)
- SIEM parsea logs diversos

Prioridad: MEDIA

OID (Object Identifier)

Definición: Identificador unico jerarquico en sistemas como SNMP, X.509, LDAP. Notacion numerica separada por puntos

Ejemplos:

- 1.3.6.1.2.1.1 (MIB-2 system group)
- OID en certificados X.509 para extensiones
- Estructura arbol: ISO.org.dod.internet...

Prioridad: COMPLEMENTARIO

OpenID Connect

Definición: Capa de autenticacion sobre OAuth 2.0. Verifica identidad usuario. ID Token (JWT). SSO moderno para web/mobile

Ejemplos:

- Sign in with Google
- Azure AD authentication
- ID Token JWT
- UserInfo endpoint
- OAuth 2.0 + Identity layer

Prioridad: ALTA

Orchestration (Orquestacion)

Definición: Coordinacion y gestion automatizada de multiples tareas y sistemas. Workflow automation complejo. Mas avanzado que automatizacion simple

Ejemplos:

- SOAR platform
- Kubernetes orchestration
- Incident response orchestration
- Coordina scripts + APIs + sistemas

Prioridad: ALTA

Out-of-Cycle Logging

Definición: Registros fuera del ciclo normal. Logs en horarios inusuales. Actividad fuera de horario laboral. Indicador de actividad sospechosa

Ejemplos:

- Admin login 3am domingo
- Backup ejecutado horario no planificado
- Script cron fuera de schedule

Prioridad: MEDIA

PCAP (Packet Capture)

Definición: Captura de paquetes de red para analisis. Formato de archivo .pcap. Wireshark, tcpdump. Analisis trafico y troubleshooting

Ejemplos:

- tcpdump -w capture.pcap
- Wireshark analysis
- Captura todo trafico red
- Analisis forense de red

Prioridad: ALTA

Package Monitoring

Definición: Monitoreo de dependencias de software (bibliotecas, frameworks). Detecta vulnerabilidades conocidas en paquetes terceros

Ejemplos:

- OWASP Dependency-Check
- Snyk
- GitHub Dependabot
- Alertar sobre Log4j vulnerable
- npm audit / pip-audit

Prioridad: ALTA

Passive Reconnaissance

Definición: Reconocimiento pasivo. Sin contacto directo con objetivo. Recopilacion de info publica. No genera alertas

Ejemplos:

- Google dorking
- WHOIS lookup
- Shodan
- DNS public records
- LinkedIn recon
- Archive.org
- NO detectable

Prioridad: ALTA

Purple Team

Definición: Colaboracion entre Red y Blue Team. Comparten conocimientos. Mejoran defensas mediante feedback. No es equipo separado

Ejemplos:

- Red Team explica tecnicas usadas
- Blue Team mejora deteccion
- Sesiones de feedback
- Threat emulation conjunta

Prioridad: MEDIA

RFID (Radio Frequency Identification)

Definición: Identificacion por radiofrecuencia. Etiquetas RFID almacenan datos. Lectura sin contacto. Tracking de objetos y acceso

Ejemplos:

- RFID access card
- Inventory tracking
- Passive RFID (sin bateria)
- Active RFID (con bateria)
- RFID cloning risk

Prioridad: MEDIA

Red Team

Definición: Equipo que simula atacantes reales. Pentest ofensivo y realista. Prueba controles de seguridad. Tacticas adversarias

Ejemplos:

- Simular APT
- Pentest sin conocimiento previo (black-box)
- Social engineering incluido
- Objetivos: comprometer red

Prioridad: ALTA

Right to be Forgotten (Derecho a ser Olvidado)

Definición: Derecho GDPR de solicitar eliminacion de datos personales. Derecho de supresion. Eliminar info de busquedas y fuentes publicas

Ejemplos:

- Eliminar datos de Google Search
- Delete cuenta y datos personales
- GDPR Article 17
- Excepciones legales aplican

Prioridad: MEDIA

SASE (Secure Access Service Edge)

Definición: Framework cloud que combina funciones de red (SD-WAN) y seguridad (SWG, CASB, FWaaS, ZTNA) en servicio unico

Ejemplos:

- Convergencia de WAN y seguridad
- Seguridad basada en identidad
- Acceso seguro desde cualquier ubicacion
- Cloudflare SASE, Zscaler

Prioridad: ALTA

SDLC (Software Development Life Cycle)

Definición: Proceso de creacion y mantenimiento de software. Fases: Planificacion, Analisis, Diseño, Implementacion, Testing, Deploy, Mantenimiento

Ejemplos:

- Waterfall SDLC
- Agile SDLC
- DevOps integration
- Secure SDLC
- Planning > Design > Code > Test > Deploy

Prioridad: ALTA

SNMP (Simple Network Management Protocol)

Definición: Protocolo de gestion de dispositivos de red. Puertos 161 (agent), 162 (trap). Versiones: v1/v2c (inseguros), v3 (cifrado)

Ejemplos:

- Monitoreo de routers/switches
- MIB (Management Information Base)
- SNMPv3 con autenticacion y cifrado
- Community strings en v1/v2c

Prioridad: MEDIA

Security Key (Llave de Seguridad)

Definición: Token hardware de autenticacion. USB/NFC. FIDO2/U2F. Phishing-resistant MFA. Dispositivo fisico para 2FA

Ejemplos:

- YubiKey
- Google Titan Key
- USB security key
- NFC tap
- WebAuthn
- Phishing-resistant

Prioridad: ALTA

Signatures (Security)

Definición: Patrones conocidos de malware/ataques. Usados por antivirus, IDS/IPS. Requiere actualizacion constante. Inefectivo contra zero-day

Ejemplos:

- Antivirus detecta hash de malware conocido
- IDS detecta patron de exploit
- Snort rules
- YARA rules

Prioridad: ALTA

Static Code Analysis (Analisis de Codigo Estatico)

Definición: Analisis de codigo fuente sin ejecutarlo. Busca bugs, vulnerabilidades, code smells. SAST. Parte de DevSecOps

Ejemplos:

- SonarQube
- Checkmarx
- Fortify
- Encuentra SQL injection en codigo
- Pre-deployment testing

Prioridad: ALTA

TAXII (Trusted Automated Exchange of Intelligence Information)

Definición: Protocolo para compartir threat intelligence. Transporte de datos STIX. APIs para intercambio automatizado de IoCs

Ejemplos:

- TAXII server recibe feeds de IoCs
- Integrar con SIEM/firewall
- Formato STIX para datos de amenazas

Prioridad: MEDIA

Technical Debt

Definición: Costo implicito de trabajo adicional futuro por soluciones rapidas/suboptimas. En seguridad: sistemas legacy sin parches, workarounds

Ejemplos:

- Sistema Windows Server 2008 sin soporte
- Hardcoded credentials pendientes de refactorizar
- Configuraciones temporales que quedaron permanentes

Prioridad: MEDIA

User Offboarding (Baja de Usuario)

Definición: Proceso cuando empleado deja empresa. Revocar accesos, recuperar activos, exit interview. Checklist de despido

Ejemplos:

- Disable AD account
- Recuperar laptop y access card
- Revoke VPN
- Exit interview
- Return company assets

Prioridad: MEDIA

User Onboarding (Incorporacion de Usuario)

Definición: Proceso de añadir nuevo empleado a sistemas. Crear cuentas, asignar permisos, hardware, training. Checklist de incorporacion

Ejemplos:

- Crear cuenta AD
- Asignar laptop
- Configurar email
- Access card
- Security training
- Sign NDA

Prioridad: MEDIA

Vulnerability Scanning

Definición: Escaneo automatizado de vulnerabilidades. Identifica debilidades de seguridad. Nessus, Qualys, OpenVAS

Ejemplos:

- Nessus scanner
- OpenVAS
- Qualys
- CVE detection
- Scheduled weekly scans
- False positives comunes

Prioridad: ALTA

White Team

Definición: Equipo neutral que arbitra ejercicio Red vs Blue. Establece reglas. Evalua desempeño. Administra ejercicio

Ejemplos:

- Coordina Red Team exercise
- Define alcance
- Evalua Blue Team response
- Administra competencia CTF

Prioridad: COMPLEMENTARIO

XML (eXtensible Markup Language)

Definición: Lenguaje de marcado para estructurar datos en formato legible para humanos y maquinas. Usado en configuraciones, APIs, SAML

Ejemplos:

- SAML assertions
- Archivos de configuracion
- SOAP web services
- Vulnerable a XXE (XML External Entity)

Prioridad: MEDIA

Dominio 5: Gestión del Programa de Seguridad

Peso examen: 20% | Términos: 54

BCP (Business Continuity Plan)

Definición: Plan para mantener operaciones criticas durante/despues de desastre. Estrategias de continuidad de negocio

Ejemplos:

- Procedimientos de failover a sitio secundario
- Funciones criticas del negocio priorizadas
- Testing anual de BCP

Prioridad: ALTA

BPA (Business Partnership Agreement)

Definición: Acuerdo de asociacion empresarial. Define relacion entre socios de negocio. Responsabilidades, profit-sharing, governance

Ejemplos:

- BPA joint venture
- Revenue sharing 60/40
- Decision-making authority
- Exit clauses

Prioridad: COMPLEMENTARIO

BYOD (Bring Your Own Device)

Definición: Modelo donde empleados usan dispositivos personales para trabajo. Riesgos seguridad. Require MDM, policies

Ejemplos:

- iPhone personal para email empresa
- MDM enrollment
- BYOD policy
- Security risks
- Work/personal data mixing

Prioridad: ALTA

Backup Generator

Definición: Generador electrico de respaldo. Arranca cuando falla alimentacion principal. Diesel/gas. Complementa UPS. Autonomia horas/dias

Ejemplos:

- Generador diesel 500kW
- Arranque automatico en 30 seg
- Tanque combustible 24h autonomia
- Testing mensual

Prioridad: MEDIA

COPE (Corporate Owned, Personally Enabled)

Definición: Empresa posee dispositivo, permite uso personal. Control corporativo + flexibilidad personal. Balance seguridad/usabilidad

Ejemplos:

- Empresa da iPhone, permite apps personales
- MDM managed
- Mas control que BYOD
- Empresa paga dispositivo

Prioridad: MEDIA

CSO (Chief Security Officer)

Definición: Director de Seguridad. Ejecutivo responsable de seguridad fisica y ciberseguridad. Protege activos, datos, personas

Ejemplos:

- Oversee CISO + physical security
- Risk management
- Security strategy
- Reporta a CEO/COO
- C-level executive

Prioridad: MEDIA

CSP (Cloud Service Provider)

Definición: Proveedor servicios cloud. Ofrece IaaS, PaaS, SaaS via Internet. AWS, Azure, GCP

Ejemplos:

- AWS
- Microsoft Azure
- Google Cloud
- IaaS/PaaS/SaaS
- Shared responsibility model

Prioridad: ALTA

CTO (Chief Technology Officer)

Definición: Director de Tecnologia. Ejecutivo responsable de decisiones tecnologicas y estrategia tech. C-level

Ejemplos:

- Estrategia tecnologica empresa
- Innovacion tech
- Arquitectura IT
- Reporta a CEO
- C-suite executive

Prioridad: COMPLEMENTARIO

CYOD (Choose Your Own Device)

Definición: Empleado elige de lista aprobada por empresa. Empresa posee y gestiona. Balance eleccion/control

Ejemplos:

- Elegir entre iPhone o Samsung aprobados
- Lista dispositivos certificados
- Empresa posee
- Estandarizacion parcial

Prioridad: MEDIA

Chain of Custody

Definición: Cadena de custodia de evidencia digital. Documentacion de quien manejo evidencia y cuando. Preserva integridad legal. Forense

Ejemplos:

- Formulario de custodia
- Hash MD5/SHA de evidencia
- Log de acceso a evidencia
- Admisibilidad en corte

Prioridad: ALTA

Cold Site

Definición: Sitio DR solo con espacio fisico y servicios basicos. Sin equipos preinstalados. RTO largo (dias/semanas). Menor costo

Ejemplos:

- Solo edificio con electricidad y conectividad
- RTO > 1 semana
- Requiere envio e instalacion equipos
- Opcion mas economica

Prioridad: ALTA

DARPA (Defense Advanced Research Projects Agency)

Definición: Agencia investigacion Defensa USA. Creador de Internet (ARPANET). Investigacion tecnologias avanzadas

Ejemplos:

- Creador ARPANET (precursor Internet)
- GPS development
- Investigacion militar avanzada
- Innovation tech

Prioridad: COMPLEMENTARIO

DRP (Disaster Recovery Plan)

Definición: Plan para recuperar sistemas IT despues de desastre. Subset de BCP enfocado en tecnologia. RTO/RPO objectives

Ejemplos:

- Procedimientos de restore desde backup
- RTO: 4 horas, RPO: 1 hora
- Hot/Warm/Cold sites
- Testing de DR

Prioridad: ALTA

GPS (Global Positioning System)

Definición: Sistema posicionamiento global por satelite. Localizacion geografica. Geotagging, tracking. Privacy concerns

Ejemplos:

- Smartphone GPS
- Geofencing apps
- Location tracking
- Privacy risks
- Geotagging photos
- Find My iPhone

Prioridad: MEDIA

Hot Site

Definición: Sitio DR completamente equipado y operacional. Replica exacta de produccion. RTO minimo (minutos/horas). Costo mas alto

Ejemplos:

- Failover automatico
- Datos sincronizados tiempo real
- RTO < 1 hora
- Personal en standby
- Mayor costo DR

Prioridad: ALTA

ICMP (Internet Control Message Protocol)

Definición: Protocolo mensajes de error y control IP. Ping, traceroute. Usado para diagnostico red. Puede ser abusado

Ejemplos:

- Ping (echo request/reply)
- Traceroute
- Destination unreachable
- ICMP flood DDoS
- Firewalls bloquean ICMP

Prioridad: ALTA

IRP (Incident Response Plan)

Definición: Plan documentado para responder a incidentes de seguridad. Define roles, procedimientos, comunicacion, escalacion

Ejemplos:

- NIST 800-61: Preparation, Detection, Analysis, Containment, Eradication, Recovery, Post-Incident
- Playbooks por tipo de incidente
- CSIRT/SOC procedures

Prioridad: ALTA

ISO (International Organization for Standardization)

Definición: Organizacion internacional de estandarizacion. Desarrolla estandares globales. ISO 27001 (seguridad info), ISO 9001 (calidad)

Ejemplos:

- ISO 27001 (ISMS)
- ISO 27002 (Security controls)
- ISO 9001 (Quality)
- ISO 22301 (Business continuity)

Prioridad: ALTA

Fases de Respuesta a Incidentes

Definición: Preparacion → Deteccion/Analisis → Contencion → Erradicacion → Recuperacion → Lecciones Aprendidas (NIST 800-61)

Ejemplos:

- Preparation: entrenar equipo, herramientas
- Detection: SIEM alerta
- Containment: aislar host
- Eradication: eliminar malware
- Recovery: restaurar servicios
- Lessons Learned: post-mortem

Prioridad: ALTA

Journaling

Definición: Registro de cambios antes de aplicarlos. Filesystem journaling. Permite recuperacion tras crash. Integridad de datos

Ejemplos:

- ext4 journal
- NTFS journal
- Database transaction log
- Recuperacion consistente tras fallo

Prioridad: MEDIA

MBR (Master Boot Record)

Definición: Primer sector disco (512 bytes). Info particiones + bootloader. Legacy (pre-UEFI). Vulnerable a bootkits

Ejemplos:

- Sector 0 del disco
- Bootloader legacy
- Max 4 particiones primarias
- Reemplazado por GPT/UEFI
- MBR rootkits

Prioridad: MEDIA

MOU (Memorandum of Understanding)

Definición: Documento de entendimiento mutuo. No legalmente vinculante. Intenciones y objetivos comunes. Menos formal que contrato

Ejemplos:

- MOU entre organizaciones para compartir threat intelligence
- Acuerdo colaboracion entre departamentos
- NO ejecutable legalmente

Prioridad: MEDIA

MSA (Master Service Agreement)

Definición: Acuerdo marco de servicio. Contrato general que gobierna relacion. Terminos y condiciones base. SOWs especificos derivan de MSA

Ejemplos:

- MSA con proveedor IT
- Define terminos generales
- SOW individuales para proyectos
- Reduce negociacion repetitiva

Prioridad: MEDIA

MTBF (Mean Time Between Failures)

Definición: Tiempo promedio entre fallos de sistema. Metrica de fiabilidad. Mayor MTBF = mas confiable. Predice disponibilidad

Ejemplos:

- Disco duro MTBF 1 millon horas
- MTBF servidor 10000 horas
- Calcular disponibilidad: MTBF/(MTBF+MTTR)

Prioridad: ALTA

MTTR (Mean Time To Repair)

Definición: Tiempo promedio para reparar sistema tras fallo. Metrica de disponibilidad. Incluye deteccion + resolucion. Menor MTTR = mejor

Ejemplos:

- MTTR 2 horas
- Calcular: suma tiempos reparacion / numero incidentes
- Objetivo: reducir MTTR
- KPI de IT ops

Prioridad: ALTA

Mobile Site

Definición: Sitio DR portatil. Trailer o contenedor con equipos IT. Se transporta a ubicacion necesaria. Flexible pero limitado

Ejemplos:

- Trailer con servidores
- Despliegue en emergencia
- DR temporal
- Uso en desastres naturales

Prioridad: COMPLEMENTARIO

NTP (Network Time Protocol)

Definición: Protocolo sincronizacion de relojes en red. UDP puerto 123. Critico para logs, Kerberos, certificados

Ejemplos:

- time.nist.gov
- Puerto UDP 123
- Stratum levels
- Kerberos require NTP
- NTP amplification attack posible

Prioridad: ALTA

OTG (USB On-The-Go)

Definición: USB que permite dispositivos actuar como host y periferico. Conectar USB devices sin PC. Moviles pueden ser host

Ejemplos:

- Conectar USB drive a smartphone
- Phone como host USB
- Cable OTG adapter
- Riesgo BadUSB attacks

Prioridad: COMPLEMENTARIO

OVAL (Open Vulnerability and Assessment Language)

Definición: Lenguaje XML para automatizar evaluacion de vulnerabilidades. MITRE standard. Describe tests de seguridad

Ejemplos:

- OVAL definitions
- Vulnerability scanners usan OVAL
- XML format
- MITRE maintained
- Compliance checking

Prioridad: MEDIA

PCI DSS (Payment Card Industry Data Security Standard)

Definición: Estandar de seguridad para industria de pagos. Protege datos de tarjetas. 12 requisitos. Obligatorio para procesadores de tarjetas

Ejemplos:

- Cifrar datos cardholder
- Firewall entre Internet y cardholder data
- No almacenar CVV
- Auditorias anuales

Prioridad: ALTA

PDU (Power Distribution Unit)

Definición: Unidad de distribucion electrica. Distribuye energia a equipos en rack. Inteligente (monitoreo) o basica. Redundancia de alimentacion

Ejemplos:

- PDU dual para redundancia
- Monitorizacion remota consumo
- Switched PDU (apagado remoto)
- PDU en rack datacenter

Prioridad: MEDIA

RAD (Rapid Application Development)

Definición: Metodologia desarrollo rapido de software. Prototipos iterativos. Colaboracion usuario. Enfoque agil

Ejemplos:

- Prototyping rapido
- Iteraciones cortas
- User feedback continuo
- Low-code platforms
- Menos documentacion

Prioridad: COMPLEMENTARIO

RAID 0

Definición: Disk Striping sin redundancia. Datos distribuidos en multiples discos. Mayor rendimiento. SIN tolerancia a fallos. Fallo de 1 disco = perdida total

Ejemplos:

- Minimo 2 discos
- Rendimiento maximo
- NO backup
- Capacidad total = suma discos
- NO recomendado para datos criticos

Prioridad: ALTA

RAID 10

Definición: RAID 1+0. Combinacion de mirroring y striping. Mirrors primero, luego stripes. Alta redundancia y rendimiento. Minimo 4 discos

Ejemplos:

- Minimo 4 discos
- Tolera multiples fallos (1 por mirror)
- Capacidad = 50%
- Alto costo
- Alto rendimiento + alta disponibilidad

Prioridad: ALTA

RAID 5

Definición: Disk Striping con paridad distribuida. Tolera fallo de 1 disco. Buen balance rendimiento/redundancia. Minimo 3 discos

Ejemplos:

- Minimo 3 discos
- Tolerancia 1 fallo
- Capacidad = (N-1) discos
- Calculo paridad XOR
- Popular en servidores

Prioridad: ALTA

RPO (Recovery Point Objective)

Definición: Maxima perdida de datos aceptable. Medido en tiempo. Frecuencia minima de backups. RPO 1 hora = backup cada hora

Ejemplos:

- RPO 4 horas
- RPO 0 (sin perdida datos) requiere replica sincrona
- Define frecuencia backup

Prioridad: ALTA

RTO (Recovery Time Objective)

Definición: Tiempo maximo aceptable para restaurar servicio. Downtime maximo tolerable. Define urgencia de recuperacion. Menor RTO = mayor costo

Ejemplos:

- RTO 2 horas
- RTO critico: minutos (hot site)
- RTO 48h (cold site)
- Define tipo de sitio DR

Prioridad: ALTA

RTP (Real-time Transport Protocol)

Definición: Protocolo para entregar audio/video sobre redes IP. Tiempo real. VoIP, streaming. Usado con RTCP

Ejemplos:

- VoIP calls
- Video streaming
- WebRTC
- SRTP (secure RTP)
- UDP-based
- Usado con SIP

Prioridad: MEDIA

Replication

Definición: Copia continua de datos a ubicacion secundaria. Sincrona o asincrona. Alta disponibilidad. Parte de estrategia DR

Ejemplos:

- Replicacion sincrona (RPO=0)
- Replicacion asincrona (RPO>0)
- Database replication
- Storage replication

Prioridad: ALTA

Risk Appetite

Definición: Cantidad de riesgo que organizacion esta dispuesta a aceptar. Nivel estrategico. Define limites de risk-taking. Guia decisiones de seguridad

Ejemplos:

- Startup tech: alto risk appetite (innovacion)
- Banco: bajo risk appetite (regulacion)
- Define threshold de aceptacion

Prioridad: MEDIA

Risk Exception

Definición: Aprobacion formal para NO remediar riesgo identificado. Decision de negocio. Acepta riesgo temporalmente con justificacion. Requiere autorizacion senior

Ejemplos:

- Sistema legacy critico no parcheable
- Costo de remediacion > impacto
- Necesita aprobacion CISO
- Revision periodica

Prioridad: ALTA

Risk Mitigation

Definición: Reducir probabilidad o impacto de riesgo. Implementar controles de seguridad. Estrategia mas comun. No elimina riesgo completamente

Ejemplos:

- Instalar firewall
- Aplicar parches
- Implementar MFA
- Training usuarios
- Reduce riesgo a nivel aceptable

Prioridad: ALTA

Risk Register (Registro de Riesgos)

Definición: Documento que identifica, evalua y rastrea riesgos. Lista completa de riesgos con: descripcion, probabilidad, impacto, mitigacion

Ejemplos:

- Riesgo 1: Ransomware - Alta prob, Alto impacto - Mitigacion: Backups
- Risk ID, Owner, Status
- Living document

Prioridad: ALTA

Risk Transference

Definición: Transferir riesgo a tercero. Tipicamente via seguro o contrato. Compartir impacto financiero. No elimina riesgo tecnico

Ejemplos:

- Seguro cibernetico
- Outsourcing a MSP
- Cloud provider SLA
- Clausulas contractuales

Prioridad: ALTA

Root Cause Analysis

Definición: Analisis de causa raiz. Investigacion profunda de incidente. Identifica causa fundamental (no sintomas). Previene recurrencia

Ejemplos:

- 5 Whys technique
- Fishbone diagram
- Post-incident RCA
- Sintoma: outage. Causa raiz: falta patch management

Prioridad: ALTA

SEH (Structured Exception Handling)

Definición: Mecanismo Windows para manejar excepciones de software. Estructura de manejo de errores. Vulnerable a exploits (SEH overwrite)

Ejemplos:

- SEH chain
- SEH overwrite exploit
- Buffer overflow to SEH
- SafeSEH mitigation
- SEHOP protection

Prioridad: COMPLEMENTARIO

SLA (Service Level Agreement)

Definición: Acuerdo formal de nivel de servicio. Define expectativas y metricas. Uptime, tiempo de respuesta. Penalizaciones por incumplimiento

Ejemplos:

- 99.9% uptime
- Respuesta en 4 horas
- SLA AWS
- Creditos por downtime
- Medicion mensual

Prioridad: ALTA

SNMP (Simple Network Management Protocol)

Definición: Protocolo gestion y monitoreo dispositivos de red. Colecta metricas. UDP 161/162. SNMPv3 seguro

Ejemplos:

- Monitor routers/switches
- MIB (Management Information Base)
- SNMPv3 authentication
- Puerto UDP 161
- SNMP traps

Prioridad: ALTA

Snapshot

Definición: Imagen punto-en-tiempo de sistema/datos. Captura estado instantaneo. Restauracion rapida. NO reemplaza backup completo

Ejemplos:

- VMware snapshot antes de cambio
- LVM snapshot
- Rollback rapido
- Storage snapshot
- NO es backup a largo plazo

Prioridad: ALTA

Tabletop Exercise

Definición: Ejercicio de simulacion de incidente basado en discusion. Participantes discuten respuesta a escenario. Sin ejecucion tecnica. Training de IR

Ejemplos:

- Simular ransomware attack
- Equipo discute pasos de respuesta
- Identificar gaps en plan IR
- No afecta produccion

Prioridad: ALTA

Technical Debt (Deuda Tecnica)

Definición: Costo de decisiones de desarrollo a corto plazo. Acumulacion de shortcuts en codigo. Problemas futuros por soluciones rapidas

Ejemplos:

- Codigo legacy sin documentar
- Parches rapidos sin refactor
- Bibliotecas obsoletas
- Acumula interes como deuda financiera

Prioridad: COMPLEMENTARIO

UEM (Unified Endpoint Management)

Definición: Gestion unificada de todos endpoints. Moviles, PCs, tablets, IoT, wearables. Evolucion de MDM + EMM

Ejemplos:

- VMware Workspace ONE
- Microsoft Intune UEM
- Gestiona mobiles + PCs + IoT
- Consola unica management

Prioridad: ALTA

Warm Site

Definición: Sitio DR parcialmente equipado. Infraestructura basica disponible. Requiere configuracion y datos. RTO medio (horas/dias). Costo moderado

Ejemplos:

- Servidores instalados pero no configurados
- RTO 12-24 horas
- Restore backup necesario
- Balance costo/tiempo

Prioridad: ALTA

Work Order (WO)

Definición: Orden de trabajo especifica. Describe tarea o proyecto puntual. Derivado de MSA o contrato. Alcance, costo, timeline

Ejemplos:

- WO: Instalar firewall nueva sucursal
- WO bajo MSA existente
- Define entregables especificos

Prioridad: COMPLEMENTARIO